

- f) instalar y actualizar regularmente software de detección y reparación de malware para escanear computadoras y medios de almacenamiento electrónico. Realización de escaneos regulares que incluyen:
 - 1) escanear cualquier dato recibido a través de redes o mediante cualquier forma de medio de almacenamiento electrónico, en busca de malware antes de su uso;
 - 2) escanear archivos adjuntos y descargas de correo electrónico y mensajería instantánea en busca de malware antes de su uso. Llevar a cabo este escaneo en diferentes lugares (por ejemplo, en servidores de correo electrónico, computadoras de escritorio) y al ingresar a la red de la organización;
 - 3) escanear páginas web en busca de malware cuando se accede a ellas;
- g) determinar la ubicación y configuración de las herramientas de detección y reparación de malware en función de los resultados de la evaluación de riesgos y considerando:
 - 1) principios de defensa en profundidad donde serían más efectivos. Por ejemplo, esto puede conducir a la detección de malware en una puerta de enlace de red (en varios protocolos de aplicación, como correo electrónico, transferencia de archivos y web), así como en servidores y dispositivos de punto final de usuario;
 - 2) las técnicas evasivas de los atacantes (p. ej., el uso de archivos cifrados) para entregar malware o el uso de protocolos de cifrado para transmitir malware;
- h) tener cuidado de protegerse contra la introducción de malware durante los procedimientos de mantenimiento y emergencia, que pueden eludir los controles normales contra el malware;
- i) implementar un proceso para autorizar la desactivación temporal o permanente de algunas o todas las medidas contra el malware, incluidas las autoridades de aprobación de excepciones, la justificación documentada y la fecha de revisión. Esto puede ser necesario cuando la protección contra malware provoca la interrupción de las operaciones normales;
- j) preparar planes de continuidad comercial apropiados para recuperarse de ataques de malware, incluidas todas las copias de seguridad de datos y software necesarias (incluidas las copias de seguridad en línea y fuera de línea) y las medidas de recuperación (ver [8.13](#));
- k) aislar ambientes donde puedan ocurrir consecuencias catastróficas;
- l) definir procedimientos y responsabilidades para tratar la protección contra malware en los sistemas, incluida la capacitación en su uso, informes y recuperación de ataques de malware;
- m) brindar conciencia o capacitación (ver [6.3](#)) a todos los usuarios sobre cómo identificar y mitigar potencialmente la recepción, el envío o la instalación de correos electrónicos, archivos o programas infectados con malware [la información recopilada en n) y o) puede usarse para garantizar que la conciencia y la capacitación se mantengan actualizadas];
- n) implementar procedimientos para recopilar regularmente información sobre nuevo malware, como suscribirse a listas de correo o revisar sitios web relevantes;
- o) verificar que la información relacionada con el malware, como los boletines de advertencia, provenga de fuentes calificadas y acreditadas (por ejemplo, sitios de Internet confiables o proveedores de software de detección de malware) y que sea precisa e informativa.

Otra información

No siempre es posible instalar software que proteja contra malware en algunos sistemas (por ejemplo, algunos sistemas de control industrial). Algunas formas de malware infectan los sistemas operativos y el firmware de la computadora, de modo que los controles de malware comunes no pueden limpiar el sistema y es necesario volver a crear una imagen completa del software del sistema operativo y, a veces, del firmware de la computadora para volver a un estado seguro.

8.8 Gestión de vulnerabilidades técnicas

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar # Proteger	# amenaza_y_vulnerabilidad_gestión	# Gobernanza_y_Ecosistema # Protección #Defensa

Control

Se debe obtener información sobre las vulnerabilidades técnicas de los sistemas de información en uso, se debe evaluar la exposición de la organización a tales vulnerabilidades y se deben tomar las medidas apropiadas.

Objetivo

Para prevenir la explotación de vulnerabilidades técnicas.

Guía

Identificación de vulnerabilidades técnicas

La organización debe tener un inventario preciso de activos (ver [5.9](#) a [5.14](#)) como requisito previo para una gestión técnica eficaz de la vulnerabilidad; el inventario debe incluir el proveedor del software, el nombre del software, los números de versión, el estado actual de implementación (por ejemplo, qué software está instalado en qué sistemas) y la(s) persona(s) dentro de la organización responsable del software.

Para identificar vulnerabilidades técnicas, la organización debe considerar:

- a) definir y establecer las funciones y responsabilidades asociadas con la gestión técnica de vulnerabilidades, incluido el monitoreo de vulnerabilidades, la evaluación de riesgos de vulnerabilidades, la actualización, el seguimiento de activos y cualquier responsabilidad de coordinación requerida;
- b) para software y otras tecnologías (basado en la lista de inventario de activos, véase [5.9](#)), identificando los recursos de información que se utilizarán para identificar vulnerabilidades técnicas relevantes y mantener la conciencia sobre ellas. Actualizar la lista de recursos de información en función de los cambios en el inventario o cuando se encuentren otros recursos nuevos o útiles;
- c) exigir a los proveedores de sistemas de información (incluidos sus componentes) que garanticen la notificación, el manejo y la divulgación de vulnerabilidades, incluidos los requisitos de los contratos aplicables (véase [5.20](#));
- d) usar herramientas de escaneo de vulnerabilidades adecuadas para las tecnologías en uso para identificar vulnerabilidades y verificar si la reparación de vulnerabilidades fue exitosa;
- e) realizar pruebas de penetración planificadas, documentadas y repetibles o evaluaciones de vulnerabilidad por parte de personas competentes y autorizadas para respaldar la identificación de vulnerabilidades. Tener precaución ya que tales actividades pueden comprometer la seguridad del sistema;
- f) rastrear el uso de bibliotecas de terceros y código fuente en busca de vulnerabilidades. Esto debe incluirse en la codificación segura (ver [8.28](#)).

La organización debe desarrollar procedimientos y capacidades para:

- a) detectar la existencia de vulnerabilidades en sus productos y servicios incluyendo cualquier componente externo utilizado en estos;
- b) recibir informes de vulnerabilidad de fuentes internas o externas.

La organización debe proporcionar un punto de contacto público como parte de una política específica de un tema sobre la divulgación de vulnerabilidades para que los investigadores y otras personas puedan informar problemas. La organización debería establecer procedimientos de notificación de vulnerabilidades, formularios de notificación en línea y hacer uso de inteligencia de amenazas o foros de intercambio de información apropiados. La organización también debe considerar los programas de recompensas por errores.

donde las recompensas se ofrecen como un incentivo para ayudar a las organizaciones a identificar vulnerabilidades para remediarlas adecuadamente. La organización también debería compartir información con los organismos competentes de la industria u otras partes interesadas.

Evaluación de vulnerabilidades técnicas

Para evaluar las vulnerabilidades técnicas identificadas, se debe considerar la siguiente guía:

- a) analizar y verificar los informes para determinar qué actividad de respuesta y remediación se necesita;
- b) una vez identificada una potencial vulnerabilidad técnica, identificar los riesgos asociados y las acciones a tomar. Tales acciones pueden implicar la actualización de sistemas vulnerables o la aplicación de otros controles.

Tomar las medidas apropiadas para abordar las vulnerabilidades técnicas

Se debe implementar un proceso de administración de actualizaciones de software para garantizar que se instalen los parches aprobados y las actualizaciones de aplicaciones más actualizados para todo el software autorizado. Si es necesario realizar cambios, se debe conservar el software original y aplicar los cambios a una copia designada. Todos los cambios deben probarse y documentarse por completo, de modo que puedan volver a aplicarse, si es necesario, a futuras actualizaciones de software. Si es necesario, las modificaciones deben ser probadas y validadas por un organismo de evaluación independiente.

Se debe considerar la siguiente orientación para abordar las vulnerabilidades técnicas:

- a) tomar medidas apropiadas y oportunas en respuesta a la identificación de posibles vulnerabilidades técnicas; definir un cronograma para reaccionar a las notificaciones de vulnerabilidades técnicas potencialmente relevantes;
- b) dependiendo de la urgencia con la que se deba abordar una vulnerabilidad técnica, llevar a cabo la acción de acuerdo con los controles relacionados con la gestión del cambio (ver [8.32](#)) o siguiendo los procedimientos de respuesta a incidentes de seguridad de la información (ver [5.26](#));
- c) utilizar únicamente actualizaciones de fuentes legítimas (que pueden ser internas o externas a la organización);
- d) probar y evaluar las actualizaciones antes de instalarlas para garantizar que sean efectivas y no produzcan efectos secundarios que no se puedan tolerar [es decir, si hay una actualización disponible, evaluar los riesgos asociados con la instalación de la actualización (los riesgos que plantea la vulnerabilidad deben compararse con el riesgo de instalar la actualización)];
- e) abordar primero los sistemas de alto riesgo;
- f) desarrollar soluciones (por lo general, actualizaciones o parches de software);
- g) prueba para confirmar si la remediación o mitigación es efectiva;
- h) proporcionar mecanismos para verificar la autenticidad de la remediación;
- i) si no hay ninguna actualización disponible o no se puede instalar la actualización, considerando otros controles, tales como:
 - 1) aplicar cualquier solución alternativa sugerida por el proveedor de software u otras fuentes relevantes;
 - 2) apagar servicios o capacidades relacionadas con la vulnerabilidad;
 - 3) adaptar o agregar controles de acceso (por ejemplo, cortafuegos) en los límites de la red (ver [8.20](#) a [8.22](#));
 - 4) proteger los sistemas, dispositivos o aplicaciones vulnerables de los ataques mediante la implementación de filtros de tráfico adecuados (a veces denominados parches virtuales);
 - 5) aumentar el monitoreo para detectar ataques reales;
 - 6) sensibilización sobre la vulnerabilidad.

Para el software adquirido, si los proveedores publican regularmente información sobre actualizaciones de seguridad para su software y brindan una instalación para instalar dichas actualizaciones automáticamente, la organización debe decidir si usar la actualización automática o no.

Otras Consideraciones

Se debe mantener un registro de auditoría para todos los pasos realizados en la gestión de vulnerabilidades técnicas.

El proceso de gestión de vulnerabilidades técnicas debe ser monitoreado y evaluado regularmente para asegurar su efectividad y eficiencia.

Un proceso eficaz de gestión de vulnerabilidades técnicas debe estar alineado con las actividades de gestión de incidentes, para comunicar datos sobre vulnerabilidades a la función de respuesta a incidentes y proporcionar procedimientos técnicos que se llevarán a cabo en caso de que ocurra un incidente.

Cuando la organización utiliza un servicio en la nube proporcionado por un proveedor de servicios en la nube externo, el proveedor de servicios en la nube debe garantizar la gestión de la vulnerabilidad técnica de los recursos del proveedor de servicios en la nube. Las responsabilidades del proveedor de servicios en la nube para la gestión de vulnerabilidades técnicas deben ser parte del acuerdo de servicios en la nube y esto debe incluir procesos para informar las acciones del proveedor de servicios en la nube relacionadas con las vulnerabilidades técnicas (ver [5.23](#)). Para algunos servicios en la nube, existen responsabilidades respectivas para el proveedor del servicio en la nube y el cliente del servicio en la nube. Por ejemplo, el cliente del servicio en la nube es responsable de la gestión de vulnerabilidades de sus propios activos utilizados para los servicios en la nube.

Otra información

La gestión de vulnerabilidades técnicas puede verse como una subfunción de la gestión de cambios y, como tal, puede aprovechar los procesos y procedimientos de gestión de cambios (ver [8.32](#)).

Existe la posibilidad de que una actualización no resuelva el problema adecuadamente y tenga efectos secundarios negativos. Además, en algunos casos, la desinstalación de una actualización no se puede lograr fácilmente una vez que se ha aplicado la actualización.

Si no es posible realizar pruebas adecuadas de las actualizaciones (por ejemplo, debido a los costos o la falta de recursos), se puede considerar un retraso en la actualización para evaluar los riesgos asociados, según la experiencia informada por otros usuarios. El uso de ISO/IEC 27031 puede ser beneficioso.

Cuando se produzcan parches o actualizaciones de software, la organización puede considerar proporcionar un proceso de actualización automatizado en el que estas actualizaciones se instalen en los sistemas o productos afectados sin necesidad de intervención por parte del cliente o el usuario. Si se ofrece un proceso de actualización automática, puede permitir que el cliente o usuario elija una opción para desactivar la actualización automática o controlar el tiempo de instalación de la actualización.

Cuando el proveedor proporciona un proceso de actualización automatizado y las actualizaciones se pueden instalar en los sistemas o productos afectados sin necesidad de intervención, la organización determina si aplica el proceso automatizado o no. Una razón para no elegir la actualización automática es mantener el control sobre cuándo se realiza la actualización. Por ejemplo, un software utilizado para una operación comercial no se puede actualizar hasta que la operación se haya completado.

Una debilidad del análisis de vulnerabilidades es que es posible que no tenga en cuenta completamente la defensa en profundidad: dos contramedidas que siempre se invocan en secuencia pueden tener vulnerabilidades que están enmascaradas por las fortalezas de la otra. La contramedida compuesta no es vulnerable, mientras que un escáner de vulnerabilidades puede informar que ambos componentes son vulnerables. Por lo tanto, la organización debe tener cuidado al revisar y actuar sobre los informes de vulnerabilidad.

Muchas organizaciones suministran software, sistemas, productos y servicios no solo dentro de la organización sino también a partes interesadas como clientes, socios u otros usuarios. Estos software, sistemas, productos y servicios pueden tener vulnerabilidades de seguridad de la información que afecten la seguridad de los usuarios.

Las organizaciones pueden publicar la remediación y divulgar información sobre las vulnerabilidades a los usuarios (generalmente a través de un aviso público) y proporcionar la información adecuada para los servicios de base de datos de vulnerabilidades de software.

Para obtener más información relacionada con la gestión de vulnerabilidades técnicas al utilizar la computación en la nube, consulte la serie ISO/IEC 19086 e ISO/IEC 27017.

ISO/IEC 29147 proporciona información detallada sobre cómo recibir informes de vulnerabilidad y publicar avisos de vulnerabilidad. ISO/IEC 30111 proporciona información detallada sobre el manejo y la resolución de vulnerabilidades informadas.

8.9 Gestión de la configuración

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# configuración_segura	# Protección

Control

Las configuraciones, incluidas las configuraciones de seguridad, de hardware, software, servicios y redes deben establecerse, documentarse, implementarse, monitorearse y revisarse.

Objetivo

Para garantizar que el hardware, el software, los servicios y las redes funcionen correctamente con la configuración de seguridad requerida, y que la configuración no se altere por cambios no autorizados o incorrectos.

Guía

General

La organización debe definir e implementar procesos y herramientas para hacer cumplir las configuraciones definidas (incluidas las configuraciones de seguridad) para el hardware, el software, los servicios (por ejemplo, servicios en la nube) y las redes, tanto para los sistemas recién instalados como para los sistemas operativos durante su vida útil.

Deben existir roles, responsabilidades y procedimientos para garantizar un control satisfactorio de todos los cambios de configuración.

Plantillas estándar

Deben definirse plantillas estándar para la configuración segura de hardware, software, servicios y redes:

- usar orientación disponible públicamente (por ejemplo, plantillas predefinidas de proveedores y de organizaciones de seguridad independientes);
- considerar el nivel de protección necesario para determinar un nivel suficiente de seguridad;
- respaldar la política de seguridad de la información de la organización, las políticas específicas del tema, las normas y otros requisitos de seguridad;
- considerar la factibilidad y aplicabilidad de las configuraciones de seguridad en el contexto de la organización.

Las plantillas deben revisarse periódicamente y actualizarse cuando sea necesario abordar nuevas amenazas o vulnerabilidades, o cuando se introduzcan nuevas versiones de software o hardware.

Se debe considerar lo siguiente para establecer plantillas estándar para la configuración segura de hardware, software, servicios y redes:

- minimizar el número de identidades con derechos de acceso privilegiados o de nivel de administrador;

- b) deshabilitar identidades innecesarias, no utilizadas o inseguras;
- c) deshabilitar o restringir funciones y servicios innecesarios;
- d) restringir el acceso a poderosos programas de utilidades y configuraciones de parámetros del host;
- e) sincronización de relojes;
- f) cambiar la información de autenticación predeterminada del proveedor, como las contraseñas predeterminadas, inmediatamente después de la instalación y revisar otros parámetros importantes relacionados con la seguridad predeterminada;
- g) invocar las instalaciones de tiempo de espera que cierran automáticamente la sesión de los dispositivos informáticos después de un período predeterminado de inactividad;
- h) verificar que se hayan cumplido los requisitos de la licencia (ver [5.32](#)).

Administrar configuraciones

Las configuraciones establecidas de hardware, software, servicios y redes deben registrarse y debe mantenerse un registro de todos los cambios de configuración. Estos registros deben almacenarse de forma segura. Esto se puede lograr de varias maneras, como bases de datos de configuración o plantillas de configuración.

Los cambios en las configuraciones deben seguir el proceso de gestión de cambios (ver [8.32](#)).

Los registros de configuración pueden contener según corresponda:

- a) información actualizada del propietario o punto de contacto del activo;
- b) fecha del último cambio de configuración;
- c) versión de la plantilla de configuración;
- d) relación con configuraciones de otros activos.

Monitoreo de configuraciones

Las configuraciones deben monitorearse con un conjunto completo de herramientas de administración del sistema (p. ej., utilidades de mantenimiento, soporte remoto, herramientas de administración empresarial, software de copia de seguridad y restauración) y deben revisarse periódicamente para verificar los ajustes de configuración, evaluar la seguridad de las contraseñas y evaluar las actividades realizadas. Las configuraciones reales se pueden comparar con las plantillas de destino definidas. Cualquier desviación debe abordarse, ya sea mediante la aplicación automática de la configuración objetivo definida o mediante el análisis manual de la desviación seguido de acciones correctivas.

Otra información

La documentación de los sistemas a menudo registra detalles sobre la configuración tanto del hardware como del software.

El endurecimiento del sistema es una parte típica de la gestión de la configuración.

La gestión de la configuración se puede integrar con los procesos de gestión de activos y las herramientas asociadas.

La automatización suele ser más eficaz para gestionar la configuración de seguridad (por ejemplo, utilizando la infraestructura como código).

Las plantillas de configuración y los destinos pueden ser información confidencial y, en consecuencia, deben protegerse contra el acceso no autorizado.

8.10 Eliminación de información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad	# Proteger	#Información_pro- tección # Legal_and_compli- ance	# Proteccion

Control

La información almacenada en sistemas de información, dispositivos o en cualquier otro medio de almacenamiento debe ser eliminada cuando ya no sea necesaria.

Objetivo

Para evitar la exposición innecesaria de información confidencial y cumplir con los requisitos legales, estatutarios, reglamentarios y contractuales para la eliminación de información.

Guía

General

La información confidencial no debe conservarse más tiempo del necesario para reducir el riesgo de divulgación no deseada.

Al eliminar información sobre sistemas, aplicaciones y servicios, se debe considerar lo siguiente:

- seleccionar un método de eliminación (p. ej., sobrescritura electrónica o borrado criptográfico) de acuerdo con los requisitos comerciales y teniendo en cuenta las leyes y reglamentos pertinentes;
- registrar los resultados de la eliminación como prueba;
- al utilizar proveedores de servicios de eliminación de información, obtener evidencia de la eliminación de información de ellos.

Cuando terceros almacenen la información de la organización en su nombre, la organización debe considerar la inclusión de requisitos sobre la eliminación de información en los acuerdos de terceros para hacerlos cumplir durante y después de la finalización de dichos servicios.

Métodos de eliminación

De acuerdo con la política de retención de datos específica del tema de la organización y teniendo en cuenta la legislación y las reglamentaciones pertinentes, la información confidencial debe eliminarse cuando ya no se necesite:

- configurar sistemas para destruir información de forma segura cuando ya no se necesite (por ejemplo, después de un período definido sujeto a la política específica del tema sobre retención de datos o por solicitud de acceso del sujeto);
- eliminar versiones obsoletas, copias y archivos temporales dondequiera que se encuentren;
- usar un software de eliminación seguro y aprobado para eliminar información de forma permanente para ayudar a garantizar que la información no se pueda recuperar mediante el uso de herramientas forenses o de recuperación especializadas;
- usar proveedores aprobados y certificados de servicios de eliminación segura;
- utilizar mecanismos de eliminación apropiados para el tipo de medio de almacenamiento que se va a eliminar (p. ej., desmagnetización de unidades de disco duro y otros medios de almacenamiento magnético).

Cuando se utilizan servicios en la nube, la organización debe verificar si el método de eliminación proporcionado por el proveedor de servicios en la nube es aceptable y, de ser así, la organización debe usarlo o solicitar que el proveedor de servicios en la nube elimine la información. Estos procesos de eliminación deben automatizarse en

de acuerdo con las políticas específicas del tema, cuando estén disponibles y sean aplicables. Dependiendo de la confidencialidad de la información eliminada, los registros pueden rastrear o verificar que estos procesos de eliminación hayan ocurrido.

Para evitar la exposición involuntaria de información confidencial cuando el equipo se devuelve a los proveedores, la información confidencial debe protegerse eliminando los almacenamientos auxiliares (por ejemplo, unidades de disco duro) y la memoria antes de que el equipo abandone las instalaciones de la organización.

Teniendo en cuenta que la eliminación segura de algunos dispositivos (por ejemplo, teléfonos inteligentes) solo se puede lograr mediante la destrucción o el uso de las funciones integradas en estos dispositivos (por ejemplo, "restaurar la configuración de fábrica"), la organización debe elegir el método apropiado de acuerdo con la clasificación de la información manejada por tales dispositivos.

Medidas de control descritas en [7.14](#) debe aplicarse para destruir físicamente el dispositivo de almacenamiento y eliminar simultáneamente la información que contiene.

Un registro oficial de borrado de información es útil a la hora de analizar la causa de un posible evento de fuga de información.

Otra información

Puede encontrar información sobre la eliminación de datos de usuario en servicios en la nube en ISO/IEC 27017.

La información sobre la eliminación de PII se puede encontrar en ISO/IEC 27555.

8.11 Enmascaramiento de datos

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad	# Proteger	# Información_protección	# Protección

Control

El enmascaramiento de datos se debe utilizar de acuerdo con la política específica del tema de la organización sobre el control de acceso y otras políticas relacionadas con el tema específico, y los requisitos comerciales, teniendo en cuenta la legislación aplicable.

Objetivo

Para limitar la exposición de datos confidenciales, incluida la PII, y para cumplir con los requisitos legales, estatutarios, reglamentarios y contractuales.

Guía

Cuando la protección de datos confidenciales (p. ej., PII) sea una preocupación, la organización debería considerar ocultar dichos datos mediante el uso de técnicas como el enmascaramiento de datos, la seudonimización o la anonimización.

Las técnicas de seudonimización o anonimización pueden ocultar la PII, disfrazar la verdadera identidad de los titulares de la PII u otra información confidencial, y desconectar el vínculo entre la PII y la identidad del titular de la PII o el vínculo entre otra información confidencial.

Cuando se utilicen técnicas de seudonimización o anonimización, se debe verificar que los datos hayan sido adecuadamente seudonimizados o anonimizados. La anonimización de datos debe considerar todos los elementos de la información sensible para ser efectivos. A modo de ejemplo, si no se considera adecuadamente, una persona puede ser identificada incluso si los datos que pueden identificarla directamente se anonimizan, por la presencia de otros datos que permiten identificar a la persona indirectamente.

Las técnicas adicionales para el enmascaramiento de datos incluyen:

- a) encriptación (que requiere que los usuarios autorizados tengan una clave);
- b) anular o eliminar caracteres (evitando que los usuarios no autorizados vean los mensajes completos);

- c) números y fechas variables;
- d) sustitución (cambiar un valor por otro para ocultar datos sensibles);
- e) reemplazar valores con su hash.

Se debe considerar lo siguiente al implementar técnicas de enmascaramiento de datos:

- a) no otorgar a todos los usuarios acceso a todos los datos, por lo tanto, diseñar consultas y máscaras para mostrar solo los datos mínimos requeridos al usuario;
- b) hay casos en los que algunos datos no deberían ser visibles para el usuario para algunos registros de un conjunto de datos; en este caso, diseñar e implementar un mecanismo para la ofuscación de datos (por ejemplo, si un paciente no quiere que el personal del hospital pueda ver todos sus registros, incluso en caso de emergencia, entonces el personal del hospital recibe datos parcialmente ofuscados y los datos solo pueden ser accedidos por personal con roles específicos si contienen información útil para un tratamiento adecuado);
- c) cuando los datos están ofuscados, dando al director de PII la posibilidad de exigir que los usuarios no puedan ver si los datos están ofuscados (ofuscación de la ofuscación; esto se usa en centros de salud, por ejemplo, si el paciente no quiere que el personal vea esa información confidencial). se ha ofuscado información como embarazos o resultados de análisis de sangre);
- d) cualquier requisito legal o reglamentario (p. ej., exigir el enmascaramiento de la información de las tarjetas de pago durante el procesamiento o el almacenamiento).

Se debe tener en cuenta lo siguiente al utilizar el enmascaramiento de datos, la seudonimización o la anonimización:

- a) nivel de fuerza del enmascaramiento de datos, seudonimización o anonimización según el uso de los datos procesados;
- b) controles de acceso a los datos procesados;
- c) acuerdos o restricciones en el uso de los datos procesados;
- d) prohibir cotejar los datos procesados con otra información para identificar al principal de la PII;
- e) realizar un seguimiento del suministro y recepción de los datos tratados.

Otra información

La anonimización altera irreversiblemente la PII de tal manera que el principal de la PII ya no se puede identificar directa o indirectamente.

La seudonimización reemplaza la información de identificación con un alias. El conocimiento del algoritmo (a veces denominado "información adicional") utilizado para realizar la seudonimización permite al menos alguna forma de identificación del principal de PII. Por lo tanto, dicha "información adicional" debe mantenerse separada y protegida.

Si bien la seudonimización es, por lo tanto, más débil que la anonimización, los conjuntos de datos seudonimizados pueden ser más útiles en la investigación estadística.

El enmascaramiento de datos es un conjunto de técnicas para ocultar, sustituir u ofuscar elementos de datos confidenciales. El enmascaramiento de datos puede ser estático (cuando los elementos de datos están enmascarados en la base de datos original), dinámico (usando automatización y reglas para proteger los datos en tiempo real) o sobre la marcha (con datos enmascarados en la memoria de una aplicación).

Las funciones hash se pueden utilizar para anonimizar la PII. Para evitar ataques de enumeración, siempre deben combinarse con una función salt.

La PII en los identificadores de recursos y sus atributos [por ejemplo, nombres de archivo, localizadores uniformes de recursos (URL)] debe evitarse o anonimizarse adecuadamente.

En ISO/IEC 27018 se proporcionan controles adicionales relacionados con la protección de PII en nubes públicas.

Información adicional sobre técnicas de desidentificación está disponible en ISO/IEC 20889.

8.12 Prevención de fuga de datos

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo # Detective	# Confidencialidad	# Proteger #Detectar	#Información_pro- tección	# Protección # Defensa

Control

Las medidas de prevención de fuga de datos deben aplicarse a los sistemas, redes y cualquier otro dispositivo que procese, almacene o transmita información confidencial.

Objetivo

Para detectar y prevenir la divulgación y extracción no autorizada de información por parte de individuos o sistemas.

Guía

La organización debería considerar lo siguiente para reducir el riesgo de fuga de datos:

a) identificar y clasificar la información para protegerla contra fugas (p. ej., información personal, modelos de precios y diseños de productos);

b) monitorear los canales de fuga de datos (por ejemplo, correo electrónico, transferencias de archivos, dispositivos móviles y dispositivos portátiles de almacenamiento);

c) actuar para evitar que se filtre información (p. ej., poner en cuarentena los correos electrónicos que contengan información confidencial).

Las herramientas de prevención de fuga de datos deben utilizarse para:

a) identificar y monitorear información sensible en riesgo de divulgación no autorizada (por ejemplo, en datos no estructurados en el sistema de un usuario);

b) detectar la divulgación de información confidencial (p. ej., cuando la información se carga en servicios en la nube de terceros no confiables o se envía por correo electrónico);

c) bloquear las acciones de los usuarios o las transmisiones de la red que expongan información confidencial (p. ej., impedir que se copien las entradas de la base de datos en una hoja de cálculo).

La organización debe determinar si es necesario restringir la capacidad de un usuario para copiar y pegar o cargar datos en servicios, dispositivos y medios de almacenamiento fuera de la organización. Si ese es el caso, la organización debe implementar tecnología como herramientas de prevención de fuga de datos o la configuración de herramientas existentes que permitan a los usuarios ver y manipular datos almacenados de forma remota pero evitar copiar y pegar fuera del control de la organización.

Si se requiere la exportación de datos, se debe permitir que el propietario de los datos apruebe la exportación y responsabilice a los usuarios por sus acciones.

La toma de capturas de pantalla o fotografías de la pantalla debe abordarse a través de los términos y condiciones de uso, capacitación y auditoría.

Cuando se realiza una copia de seguridad de los datos, se debe tener cuidado para garantizar que la información confidencial esté protegida mediante medidas como el cifrado, el control de acceso y la protección física de los medios de almacenamiento que contienen la copia de seguridad.

También se debe considerar la prevención de fuga de datos para protegerse contra las acciones de inteligencia de un adversario de obtener información confidencial o secreta (geopolítica, humana, financiera, comercial, científica o cualquier otra) que puede ser de interés para el espionaje o puede ser crítica para la comunidad. . El

Las acciones de prevención de fuga de datos deben estar orientadas a confundir las decisiones del adversario, por ejemplo, reemplazando información auténtica con información falsa, ya sea como una acción independiente o como respuesta a las acciones de inteligencia del adversario. Ejemplos de este tipo de acciones son la ingeniería social inversa o el uso de honeypots para atraer a los atacantes.

Otra información

Las herramientas de prevención de fuga de datos están diseñadas para identificar datos, monitorear el uso y el movimiento de datos y tomar medidas para evitar la fuga de datos (por ejemplo, alertar a los usuarios sobre su comportamiento de riesgo y bloquear la transferencia de datos a dispositivos portátiles de almacenamiento).

La prevención de la fuga de datos implica de forma inherente el control de las comunicaciones y las actividades en línea del personal y, por extensión, los mensajes de terceros, lo que plantea problemas legales que deben tenerse en cuenta antes de implementar herramientas de prevención de la fuga de datos. Existe una variedad de legislación relacionada con la privacidad, la protección de datos, el empleo, la interceptación de datos y las telecomunicaciones que es aplicable al monitoreo y procesamiento de datos en el contexto de la prevención de fugas de datos.

La prevención de la fuga de datos puede estar respaldada por controles de seguridad estándar, como políticas específicas de un tema sobre el control de acceso y la gestión segura de documentos (consulte [5.12](#) y [5.15](#)).

8.13 Copia de seguridad de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Correctivo	# Integridad # Disponibilidad	# Recuperar	# Continuidad	# Protección

Control

Las copias de respaldo de la información, el software y los sistemas deben mantenerse y probarse regularmente de acuerdo con la política de respaldo específica del tema acordada.

Objetivo

Para permitir la recuperación de la pérdida de datos o sistemas.

Guía

Se debe establecer una política de respaldo específica del tema para abordar los requisitos de seguridad de la información y retención de datos de la organización.

Se deben proporcionar instalaciones de respaldo adecuadas para garantizar que toda la información y el software esenciales se puedan recuperar después de un incidente, falla o pérdida de medios de almacenamiento.

Se deben desarrollar e implementar planes sobre cómo la organización respaldará la información, el software y los sistemas, para abordar la política específica del tema sobre respaldo.

Al diseñar un plan de respaldo, se deben tener en cuenta los siguientes elementos:

- la producción de registros precisos y completos de las copias de seguridad y los procedimientos de restauración documentados;
- reflejar los requisitos comerciales de la organización (p. ej., el objetivo del punto de recuperación, véase [5.30](#)), los requisitos de seguridad de la información involucrada y la criticidad de la información para la operación continua de la organización en la medida (por ejemplo, copia de seguridad completa o diferencial) y la frecuencia de las copias de seguridad;
- almacenar las copias de seguridad en una ubicación remota segura y protegida, a una distancia suficiente para escapar de cualquier daño de un desastre en el sitio principal;
- dar a la información de respaldo un nivel adecuado de protección física y ambiental (ver [Cláusula 7](#) y [8.1](#)) consistente con los estándares aplicados en el sitio principal;

- e) probar regularmente los medios de respaldo para garantizar que se pueda confiar en ellos para uso de emergencia cuando sea necesario. Probar la capacidad de restaurar datos respaldados en un sistema de prueba, sin sobrescribir los medios de almacenamiento originales en caso de que el proceso de respaldo o restauración falle y cause daños o pérdidas irreparables de datos;
- f) proteger las copias de seguridad mediante encriptación de acuerdo con los riesgos identificados (por ejemplo, en situaciones donde la confidencialidad es importante);
- g) asegurarse de que se detecte la pérdida inadvertida de datos antes de realizar la copia de seguridad.

Los procedimientos operativos deben monitorear la ejecución de las copias de seguridad y abordar las fallas de las copias de seguridad programadas para garantizar la integridad de las copias de seguridad de acuerdo con la política de copias de seguridad específica del tema.

Las medidas de respaldo para los sistemas y servicios individuales deben probarse regularmente para garantizar que cumplan con los objetivos de los planes de respuesta a incidentes y continuidad del negocio (ver [5.30](#)). Esto debe combinarse con una prueba de los procedimientos de restauración y compararse con el tiempo de restauración requerido por el plan de continuidad del negocio. En el caso de sistemas y servicios críticos, las medidas de respaldo deben cubrir toda la información de los sistemas, las aplicaciones y los datos necesarios para recuperar el sistema completo en caso de un desastre.

Cuando la organización utiliza un servicio en la nube, se deben realizar copias de seguridad de la información, las aplicaciones y los sistemas de la organización en el entorno del servicio en la nube. La organización debe determinar si se cumplen los requisitos de copia de seguridad y cómo se cumplen cuando se utiliza el servicio de copia de seguridad de la información proporcionado como parte del servicio en la nube.

El período de retención de la información comercial esencial debe determinarse, teniendo en cuenta cualquier requisito para la retención de copias de archivo. La organización debe considerar la eliminación de la información (ver [8.10](#)) en los medios de almacenamiento utilizados para la copia de seguridad una vez que expire el período de retención de la información y debe tener en cuenta la legislación y las reglamentaciones.

Otra información

Para obtener más información sobre la seguridad del almacenamiento, incluida la consideración de retención, consulte ISO/IEC 27040.

8.14 Redundancia de las instalaciones de procesamiento de información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Disponibilidad	# Proteger	# Continuidad # Gestión de activos	# Protección # Resiliencia

Control

Las instalaciones de procesamiento de información deben implementarse con suficiente redundancia para cumplir con los requisitos de disponibilidad.

Objetivo

Asegurar el funcionamiento continuo de las instalaciones de procesamiento de información.

Guía

La organización debería identificar los requisitos para la disponibilidad de los servicios de negocio y los sistemas de información. La organización debe diseñar e implementar una arquitectura de sistemas con la redundancia adecuada para cumplir con estos requisitos.

La redundancia se puede introducir duplicando las instalaciones de procesamiento de información en parte o en su totalidad (es decir, componentes de repuesto o tener dos de todo). La organización debería planificar e implementar procedimientos para la activación de los componentes redundantes y las instalaciones de procesamiento. Los procedimientos deben establecer si los componentes redundantes y las actividades de procesamiento son siempre

activada, o en caso de emergencia, automática o manualmente. Los componentes redundantes y las instalaciones de procesamiento de información deben garantizar el mismo nivel de seguridad que los principales.

Deben existir mecanismos para alertar a la organización sobre cualquier falla en las instalaciones de procesamiento de información, permitir la ejecución del procedimiento planificado y permitir la disponibilidad continua mientras se reparan o reemplazan las instalaciones de procesamiento de información.

La organización debe considerar lo siguiente al implementar sistemas redundantes:

- a) contratar con dos o más proveedores de redes e instalaciones críticas de procesamiento de información, como proveedores de servicios de Internet;
- b) usar redes redundantes;
- c) utilizar dos centros de datos separados geográficamente con sistemas duplicados;
- d) utilizar fuentes o fuentes de alimentación físicamente redundantes;
- e) uso de múltiples instancias paralelas de componentes de software, con equilibrio de carga automático entre ellas (entre instancias en el mismo centro de datos o en diferentes centros de datos);
- f) tener componentes duplicados en los sistemas (por ejemplo, CPU, discos duros, memorias) o en redes (por ejemplo, cortafuegos, enrutadores, conmutadores).

Cuando corresponda, preferiblemente en modo de producción, los sistemas de información redundantes deben probarse para garantizar que la conmutación por error de un componente a otro funcione según lo previsto.

Otra información

Existe una fuerte relación entre la redundancia y la preparación de las TIC para la continuidad del negocio (ver [5.30](#)) especialmente si se requieren tiempos de recuperación cortos. Muchas de las medidas de redundancia pueden formar parte de las estrategias y soluciones de continuidad de las TIC.

La implementación de redundancias puede presentar riesgos para la integridad (p. ej., los procesos de copia de datos en componentes duplicados pueden introducir errores) o la confidencialidad (p. ej., un control de seguridad débil de los componentes duplicados puede comprometer) la información y los sistemas de información, que deben tenerse en cuenta al diseñar sistemas de información.

La redundancia en las instalaciones de procesamiento de información no suele abordar la indisponibilidad de la aplicación debido a fallas dentro de una aplicación.

Con el uso de la computación en la nube pública, es posible tener múltiples versiones en vivo de las instalaciones de procesamiento de información, existentes en múltiples ubicaciones físicas separadas con conmutación por error automática y equilibrio de carga entre ellas.

Algunas de las tecnologías y técnicas para proporcionar redundancia y conmutación por error automática en el contexto de los servicios en la nube se analizan en ISO/IEC TS 23167.

8.15 Registro

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Detective	# Confidencialidad # Integridad # Disponibilidad	# Detectar	# Information_security_event_management	# Protección # Defensa

Control

Se deben producir, almacenar, proteger y analizar registros que registren actividades, excepciones, fallas y otros eventos relevantes.

Objetivo

Para registrar eventos, generar evidencia, garantizar la integridad de la información de registro, prevenir el acceso no autorizado, identificar eventos de seguridad de la información que pueden conducir a un incidente de seguridad de la información y respaldar investigaciones.

Guía

General

La organización debe determinar el propósito para el cual se crean los registros, qué datos se recopilan y registran y cualquier requisito específico del registro para proteger y manejar los datos de registro. Esto debe documentarse en una política específica del tema sobre el registro.

Los registros de eventos deben incluir para cada evento, según corresponda:

a) identificaciones de usuario;

b) actividades del sistema;

c) fechas, horas y detalles de eventos relevantes (por ejemplo, inicio y cierre de sesión);

d) identidad del dispositivo, identificador del sistema y ubicación;

e) direcciones de red y protocolos.

Los siguientes eventos deben ser considerados para el registro:

a) intentos de acceso al sistema exitosos y rechazados;

b) datos exitosos y rechazados y otros intentos de acceso a recursos;

c) cambios en la configuración del sistema;

d) uso de privilegios;

e) uso de programas de utilidad y aplicaciones;

f) los archivos a los que se accede y el tipo de acceso, incluida la eliminación de archivos de datos importantes;

g) alarmas emitidas por el sistema de control de acceso;

h) activación y desactivación de sistemas de seguridad, como sistemas antivirus y sistemas de detección de intrusos;

i) creación, modificación o supresión de identidades;

j) transacciones ejecutadas por los usuarios en las aplicaciones. En algunos casos, las aplicaciones son un servicio o producto proporcionado o ejecutado por un tercero.

Es importante que todos los sistemas tengan fuentes de tiempo sincronizadas (ver [8.17](#)) ya que esto permite la correlación de registros entre sistemas para el análisis, alerta e investigación de un incidente.

Protección de registros

Los usuarios, incluidos aquellos con derechos de acceso privilegiados, no deben tener permiso para eliminar o desactivar registros de sus propias actividades. Pueden potencialmente manipular los registros en las instalaciones de procesamiento de información bajo su control directo. Por lo tanto, es necesario proteger y revisar los registros para mantener la responsabilidad de los usuarios privilegiados.

Los controles deben tener como objetivo proteger contra cambios no autorizados en la información de registro y problemas operativos con la instalación de registro, incluidos:

a) alteraciones en los tipos de mensajes que se registran;

b) archivos de registro que se están editando o eliminando;

c) falla en el registro de eventos o sobreescritura de eventos pasados registrados si se excede el medio de almacenamiento que contiene un archivo de registro.

Para la protección de los registros, se debe considerar el uso de las siguientes técnicas: hashing criptográfico, registro en un archivo de solo lectura y solo para agregar, registro en un archivo de transparencia pública.

Es posible que se requiera archivar algunos registros de auditoría debido a los requisitos sobre la retención de datos o los requisitos para recopilar y conservar evidencia (ver [5.28](#)).

Cuando la organización necesite enviar registros del sistema o de la aplicación a un proveedor para ayudar con la depuración o la resolución de errores, los registros deben anonimizarse cuando sea posible utilizando técnicas de enmascaramiento de datos (ver [8.11](#)) para obtener información como nombres de usuario, direcciones de protocolo de Internet (IP), nombres de host o nombre de la organización, antes de enviarlo al proveedor.

Los registros de eventos pueden contener datos confidenciales e información de identificación personal. Deben tomarse las medidas adecuadas de protección de la privacidad (ver [5.34](#)).

Análisis de registro

El análisis de registros debe cubrir el análisis y la interpretación de los eventos de seguridad de la información, para ayudar a identificar actividades inusuales o comportamientos anómalos, que pueden representar indicadores de compromiso.

El análisis de los eventos debe realizarse teniendo en cuenta:

- a) las habilidades necesarias para los expertos que realizan el análisis;
- b) determinar el procedimiento de análisis de registros;
- c) los atributos requeridos de cada evento relacionado con la seguridad;
- d) excepciones identificadas mediante el uso de reglas predeterminadas [por ejemplo, gestión de eventos e información de seguridad (SIEM) o reglas de cortafuegos, y sistemas de detección de intrusos (IDS) o firmas de malware];
- e) patrones de comportamiento conocidos y tráfico de red estándar en comparación con actividad y comportamiento anómalos [análisis de comportamiento de usuarios y entidades (UEBA)];
- f) resultados del análisis de tendencias o patrones (p. ej., como resultado del uso de análisis de datos, técnicas de macrodatos y herramientas de análisis especializadas);
- g) inteligencia de amenazas disponible.

El análisis de registros debe estar respaldado por actividades de monitoreo específicas para ayudar a identificar y analizar el comportamiento anómalo, que incluye:

- a) revisar los intentos exitosos y fallidos de acceder a los recursos protegidos [por ejemplo, servidores del sistema de nombres de dominio (DNS), portales web y recursos compartidos de archivos];
- b) verificar los registros de DNS para identificar conexiones de red salientes a servidores maliciosos, como los asociados con servidores de comando y control de botnet;
- c) examinar los informes de uso de los proveedores de servicios (p. ej., facturas o informes de servicios) en busca de actividad inusual dentro de los sistemas y redes (p. ej., mediante la revisión de patrones de actividad);
- d) incluir registros de eventos de monitoreo físico, como entrada y salida, para garantizar una detección y un análisis de incidentes más precisos;
- e) correlación de registros para permitir un análisis eficiente y altamente preciso.

Los incidentes de seguridad de la información presuntos y reales deben identificarse (p. ej., infección de malware o sondeo de cortafuegos) y estar sujetos a una mayor investigación (p. ej., como parte de un proceso de gestión de incidentes de seguridad de la información, consulte [5.25](#)).

Otra información

Los registros del sistema suelen contener un gran volumen de información, gran parte de la cual es ajena al control de la seguridad de la información. Para ayudar a identificar eventos significativos con fines de monitoreo de la seguridad de la información, se puede considerar el uso de programas de utilidad o herramientas de auditoría adecuados para realizar la interrogación de archivos.

El registro de eventos sienta las bases para los sistemas de monitoreo automatizados (ver [8.16](#)) que son capaces de generar informes consolidados y alertas sobre la seguridad del sistema.

Se puede utilizar una herramienta SIEM o un servicio equivalente para almacenar, correlacionar, normalizar y analizar la información de registro., y generar alertas. Los SIEM tienden a requerir una configuración cuidadosa para optimizar sus beneficios. Las configuraciones a considerar incluyen la identificación y selección de fuentes de registro apropiadas, ajuste y prueba de reglas y desarrollo de casos de uso.

Los archivos de transparencia pública para el registro de registros se utilizan, por ejemplo, en sistemas de transparencia de certificados. Dichos archivos pueden proporcionar un mecanismo de detección adicional útil para protegerse contra la manipulación del registro.

En entornos de nube, las responsabilidades de gestión de registros se pueden compartir entre el cliente del servicio de nube y el proveedor de servicios de nube. Las responsabilidades varían según el tipo de servicio en la nube que se utilice. Se puede encontrar más orientación en ISO/IEC 27017.

8.16 Actividades de seguimiento

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Detective # Correctivo	# Confidencialidad # Integridad #Disponibilidad	# Detectar #Responder	# Information_security_event_management	# Defensa

Control

Las redes, los sistemas y las aplicaciones deben monitorearse para detectar comportamientos anómalos y deben tomarse las medidas apropiadas para evaluar posibles incidentes de seguridad de la información.

Objetivo

Para detectar comportamientos anómalos y posibles incidentes de seguridad de la información.

Guía

El alcance y el nivel de monitoreo deben determinarse de acuerdo con los requisitos de seguridad de la información y del negocio y teniendo en cuenta las leyes y regulaciones pertinentes. Los registros de seguimiento deben mantenerse durante períodos de retención definidos.

Lo siguiente debe ser considerado para su inclusión dentro del sistema de monitoreo:

- a) tráfico de red, sistema y aplicación entrante y saliente;
- b) acceso a sistemas, servidores, equipos de red, sistema de monitoreo, aplicaciones críticas, etc.;
- c) archivos de configuración de red y sistema de nivel crítico o administrativo;
- d) registros de herramientas de seguridad [por ejemplo, antivirus, IDS, sistema de prevención de intrusiones (IPS), filtros web, cortafuegos, prevención de fuga de datos];
- e) registros de eventos relacionados con la actividad del sistema y de la red;

f) comprobar que el código que se ejecuta está autorizado para ejecutarse en el sistema y que no ha sido alterado (p. ej., mediante recompilación para agregar código adicional no deseado);

g) uso de los recursos (por ejemplo, CPU, discos duros, memoria, ancho de banda) y su rendimiento.

La organización debe establecer una línea de base de comportamiento normal y monitorear contra esta línea de base para detectar anomalías. Al establecer una línea de base, se debe considerar lo siguiente:

a) revisar la utilización de los sistemas en períodos normales y pico;

b) hora habitual de acceso, lugar de acceso, frecuencia de acceso para cada usuario o grupo de usuarios.

El sistema de monitoreo debe configurarse contra la línea de base establecida para identificar comportamientos anómalos, tales como:

a) terminación no planificada de procesos o aplicaciones;

b) actividad típicamente asociada con malware o tráfico que se origina en direcciones IP o dominios de red maliciosos conocidos (por ejemplo, aquellos asociados con servidores de comando y control de botnet);

c) características de ataque conocidas (por ejemplo, denegación de servicio y desbordamiento de memoria intermedia);

d) comportamiento inusual del sistema (por ejemplo, registro de pulsaciones de teclas, inyección de procesos y desviaciones en el uso de protocolos estándar);

e) cuellos de botella y sobrecargas (por ejemplo, colas de la red, niveles de latencia y fluctuaciones de la red);

f) acceso no autorizado (real o intentado) a sistemas o información;

g) escaneo no autorizado de aplicaciones comerciales, sistemas y redes;

h) intentos exitosos y fallidos de acceder a recursos protegidos (por ejemplo, servidores DNS, portales web y sistemas de archivos);

i) comportamiento inusual del usuario y del sistema en relación con el comportamiento esperado.

Se debe utilizar un monitoreo continuo a través de una herramienta de monitoreo. El monitoreo debe hacerse en tiempo real o en intervalos periódicos, sujeto a las necesidades y capacidades de la organización. Las herramientas de monitoreo deben incluir la capacidad de manejar grandes cantidades de datos, adaptarse a un panorama de amenazas en constante cambio y permitir la notificación en tiempo real. Las herramientas también deberían poder reconocer firmas y datos específicos o patrones de comportamiento de la red o la aplicación.

El software de monitoreo automatizado debe configurarse para generar alertas (por ejemplo, a través de consolas de administración, mensajes de correo electrónico o sistemas de mensajería instantánea) en función de umbrales predefinidos. El sistema de alerta debe ajustarse y capacitarse en la línea de base de la organización para minimizar los falsos positivos. El personal debe estar dedicado a responder a las alertas y debe estar debidamente capacitado para interpretar con precisión los posibles incidentes. Debe haber sistemas y procesos redundantes para recibir y responder a las notificaciones de alerta.

Los eventos anormales deben comunicarse a las partes relevantes para mejorar las siguientes actividades: auditoría, evaluación de seguridad, exploración y monitoreo de vulnerabilidades (ver [5.25](#)). Deben existir procedimientos para responder a los indicadores positivos del sistema de monitoreo de manera oportuna, a fin de minimizar el efecto de los eventos adversos (ver [5.26](#)) sobre seguridad de la información. También se deben establecer procedimientos para identificar y abordar los falsos positivos, incluido el ajuste del software de monitoreo para reducir la cantidad de falsos positivos en el futuro.

Otra información

El monitoreo de la seguridad se puede mejorar mediante:

a) aprovechar los sistemas de inteligencia de amenazas (ver [5.7](#));

b) aprovechar las capacidades de aprendizaje automático e inteligencia artificial;

- c) usar listas de bloqueo o listas de permitidos;
- d) realizar una variedad de evaluaciones técnicas de seguridad (p. ej., evaluaciones de vulnerabilidad, pruebas de penetración, simulaciones de ataques cibernéticos y ejercicios de respuesta cibernética) y usar los resultados de estas evaluaciones para ayudar a determinar las líneas de base o el comportamiento aceptable;
- e) utilizar sistemas de seguimiento del rendimiento para ayudar a establecer y detectar comportamientos anómalos;
- f) aprovechamiento de registros en combinación con sistemas de seguimiento.

Las actividades de monitoreo a menudo se realizan utilizando software especializado, como los sistemas de detección de intrusos. Estos se pueden configurar a una línea de base de actividades normales, aceptables y esperadas del sistema y de la red.

El monitoreo de comunicaciones anómalas ayuda en la identificación de botnets (es decir, un conjunto de dispositivos bajo el control malicioso del propietario de la botnet, generalmente utilizados para montar ataques distribuidos de denegación de servicio en otras computadoras de otras organizaciones). Si la computadora está siendo controlada por un dispositivo externo, existe una comunicación entre el dispositivo infectado y el controlador. Por lo tanto, la organización debe emplear tecnologías para monitorear comunicaciones anómalas y tomar las medidas necesarias.

8.17 Sincronización del reloj

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Detective	# Integridad	# Proteger #Detectar	# Information_security_event_management	# Protección # Defensa

Control

Los relojes de los sistemas de procesamiento de información utilizados por la organización deben sincronizarse con las fuentes de tiempo aprobadas.

Objetivo

Permitir la correlación y el análisis de eventos relacionados con la seguridad y otros datos registrados, y respaldar las investigaciones sobre incidentes de seguridad de la información.

Guía

Los requisitos externos e internos para la representación del tiempo, la sincronización confiable y la precisión deben documentarse e implementarse. Dichos requisitos pueden provenir de necesidades legales, estatutarias, reglamentarias, contractuales, estándares y de control interno. Se debe definir y considerar un tiempo de referencia estándar para uso dentro de la organización para todos los sistemas, incluidos los sistemas de administración de edificios, los sistemas de entrada y salida y otros que se pueden usar para ayudar en las investigaciones.

Un reloj vinculado a una transmisión de tiempo por radio desde un reloj atómico nacional o un sistema de posicionamiento global (GPS) debe usarse como reloj de referencia para los sistemas de registro; una fuente de fecha y hora consistente y confiable para garantizar sellos de tiempo precisos. Deben utilizarse protocolos como el protocolo de tiempo de red (NTP) o el protocolo de tiempo de precisión (PTP) para mantener todos los sistemas en red sincronizados con un reloj de referencia.

La organización puede usar dos fuentes de tiempo externas al mismo tiempo para mejorar la confiabilidad de los relojes externos y administrar adecuadamente cualquier variación.

La sincronización del reloj puede ser difícil cuando se usan múltiples servicios en la nube o cuando se usan tanto servicios en la nube como locales. En este caso, se debe monitorear el reloj de cada servicio y registrar la diferencia para mitigar los riesgos derivados de las discrepancias.

Otra información

La configuración correcta de los relojes de las computadoras es importante para garantizar la precisión de los registros de eventos, que pueden ser necesarios para investigaciones o como evidencia en casos legales y disciplinarios. Los registros de auditoría inexactos pueden dificultar dichas investigaciones y dañar la credibilidad de dicha evidencia.

8.18 Uso de programas de utilidad privilegiados

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# sistema_y_red- trabajo_seguridad # Secure_configura- ción #Aplicación_seguridad	# Proteccion

Control

El uso de programas de utilidad que puedan anular los controles del sistema y de las aplicaciones debe restringirse y controlarse estrictamente.

Objetivo

Para garantizar que el uso de programas de utilidad no dañe el sistema y los controles de aplicaciones para la seguridad de la información.

Guía

Se deben considerar las siguientes pautas para el uso de programas de utilidad que pueden anular los controles del sistema y de la aplicación:

- limitación del uso de programas de utilidad al número mínimo práctico de usuarios autorizados de confianza (ver [8.2](#));
- uso de procedimientos de identificación, autenticación y autorización para programas de utilidad, incluida la identificación única de la persona que usa el programa de utilidad;
- definición y documentación de niveles de autorización para programas de servicios;
- autorización para uso ad hoc de programas utilitarios;
- no poner programas de utilidad a disposición de los usuarios que tienen acceso a aplicaciones en sistemas donde se requiere segregación de funciones;
- eliminar o deshabilitar todos los programas de utilidad innecesarios;
- como mínimo, separación lógica de los programas de utilidad del software de aplicación. Cuando sea práctico, segregar las comunicaciones de red para tales programas del tráfico de aplicaciones;
- limitación de la disponibilidad de los programas de utilidad (por ejemplo, durante la duración de un cambio autorizado);
- registro de todos los usos de los programas de utilidad.

Otra información

La mayoría de los sistemas de información tienen uno o más programas de utilidad que pueden anular los controles del sistema y de las aplicaciones, por ejemplo, diagnósticos, parches, antivirus, desfragmentadores de disco, depuradores, copias de seguridad y herramientas de red.

8.19 Instalación de software en sistemas operativos

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Seguridad do- red eléctrica
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# configuración_segura #Aplicación_seguridad	# Proteccion

Control

Deben implementarse procedimientos y medidas para gestionar de forma segura la instalación de software en los sistemas operativos.

Objetivo

Para garantizar la integridad de los sistemas operativos y evitar la explotación de vulnerabilidades técnicas.

Guía

Se deben considerar las siguientes pautas para administrar de forma segura los cambios y la instalación de software en los sistemas operativos:

- realizar actualizaciones del software operativo solo por parte de administradores capacitados con la autorización de gestión adecuada (ver [8.5](#));
- garantizar que solo se instale código ejecutable aprobado y ningún código de desarrollo o compiladores en los sistemas operativos;
- solo instalar y actualizar el software después de pruebas extensas y exitosas (ver [8.29](#) y [8.31](#));
- actualizar todas las bibliotecas fuente de programas correspondientes;
- usar un sistema de control de configuración para mantener el control de todo el software operativo, así como la documentación del sistema;
- definir una estrategia de reversión antes de que se implementen los cambios;
- mantener un registro de auditoría de todas las actualizaciones del software operativo;
- archivar versiones antiguas de software, junto con toda la información y parámetros requeridos, procedimientos, detalles de configuración y software de soporte como medida de contingencia, y durante el tiempo que se requiera que el software lea o procese datos archivados.

Cualquier decisión de actualizar a una nueva versión debe tener en cuenta los requisitos comerciales para el cambio y la seguridad de la versión (por ejemplo, la introducción de una nueva funcionalidad de seguridad de la información o el número y la gravedad de las vulnerabilidades de seguridad de la información que afectan a la versión actual). Los parches de software deben aplicarse cuando puedan ayudar a eliminar o reducir las vulnerabilidades de seguridad de la información (ver [8.8](#) y [8.19](#)).

El software de computadora puede basarse en software y paquetes suministrados externamente (por ejemplo, programas de software que utilizan módulos alojados en sitios externos), que deben monitorearse y controlarse para evitar cambios no autorizados, ya que pueden introducir vulnerabilidades de seguridad de la información.

El software suministrado por el proveedor que se utiliza en los sistemas operativos debe mantenerse en un nivel respaldado por el proveedor. Con el tiempo, los proveedores de software dejarán de admitir versiones anteriores de software. La organización debe considerar los riesgos de depender de software sin soporte. El software de código abierto utilizado en los sistemas operativos debe mantenerse hasta la última versión adecuada del software. Con el tiempo, el código fuente abierto puede dejar de mantenerse, pero aún está disponible en un repositorio de software de código abierto. La organización también debe considerar los riesgos de confiar en software de código abierto sin mantenimiento cuando se usa en sistemas operativos.

Cuando los proveedores estén involucrados en la instalación o actualización de software, el acceso físico o lógico solo debe otorgarse cuando sea necesario y con la debida autorización. Las actividades del proveedor deben ser monitoreadas (ver [5.22](#)).

La organización debe definir y hacer cumplir reglas estrictas sobre qué tipos de software pueden instalar los usuarios.

El principio de privilegio mínimo debe aplicarse a la instalación de software en sistemas operativos. La organización debe identificar qué tipos de instalaciones de software están permitidas (p. ej., actualizaciones y parches de seguridad para el software existente) y qué tipos de instalaciones están prohibidas (p. ej., software que es solo para uso personal y software cuyo pedigrí con respecto a ser potencialmente malicioso se desconoce o sospechar). Estos privilegios deben otorgarse en función de las funciones de los usuarios en cuestión.

Otra información

Ninguna otra información.

8.20 Seguridad de redes

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo # Detective	# Confidencialidad # Integridad # Disponibilidad	# Proteger #Detectar	# sistema_y_red- trabajo_seguridad	# Proteccion

Control

Las redes y los dispositivos de red deben protegerse, administrarse y controlarse para proteger la información en los sistemas y aplicaciones.

Objetivo

Para proteger la información en las redes y sus instalaciones de procesamiento de información de apoyo del compromiso a través de la red.

Guía

Se deben implementar controles para garantizar la seguridad de la información en las redes y para proteger los servicios conectados del acceso no autorizado. En particular, se deben considerar los siguientes elementos:

- el tipo y nivel de clasificación de la información que la red puede soportar;
- establecer responsabilidades y procedimientos para la gestión de equipos y dispositivos de red;
- mantener la documentación actualizada, incluidos los diagramas de red y los archivos de configuración de los dispositivos (por ejemplo, enrutadores, conmutadores);
- separar la responsabilidad operativa de las redes de las operaciones del sistema TIC cuando corresponda (ver [5.3](#));
- establecer controles para salvaguardar la confidencialidad e integridad de los datos que pasan por redes públicas, redes de terceros o redes inalámbricas y para proteger los sistemas y aplicaciones conectados (ver [5.22](#) , [8.24](#) , [5.14](#) y [6.6](#)). También se pueden requerir controles adicionales para mantener la disponibilidad de los servicios de red y las computadoras conectadas a la red;
- registro y monitoreo adecuados para permitir el registro y la detección de acciones que pueden afectar o son relevantes para la seguridad de la información (ver [8.16](#) y [8.15](#));
- coordinar estrechamente las actividades de gestión de la red tanto para optimizar el servicio a la organización como para garantizar que los controles se apliquen de forma coherente en toda la infraestructura de procesamiento de la información;

- h) sistemas de autenticación en la red;
- i) restringir y filtrar la conexión de los sistemas a la red (por ejemplo, usando firewalls);
- j) detectar, restringir y autenticar la conexión de equipos y dispositivos a la red;
- k) endurecimiento de los dispositivos de red;
- l) segregar los canales de administración de red de otro tráfico de red;
- m) aislar temporalmente subredes críticas (por ejemplo, con puentes levadizos) si la red está bajo ataque;
- n) deshabilitar protocolos de red vulnerables.

La organización debe garantizar que se apliquen los controles de seguridad adecuados al uso de redes virtualizadas. Las redes virtualizadas también cubren las redes definidas por software (SDN, SD-WAN). Las redes virtualizadas pueden ser deseables desde el punto de vista de la seguridad, ya que pueden permitir la separación lógica de la comunicación que tiene lugar en las redes físicas, en particular para los sistemas y aplicaciones que se implementan mediante computación distribuida.

Otra información

Puede encontrar información adicional sobre la seguridad de la red en la serie ISO/IEC 27033.

Se puede encontrar más información sobre redes virtualizadas en ISO/IEC TS 23167.

8.21 Seguridad de los servicios de red

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# sistema_y_red- trabajo_seguridad	# Proteccion

Control

Los mecanismos de seguridad, los niveles de servicio y los requisitos de servicio de los servicios de red deben identificarse, implementarse y monitorearse.

Objetivo

Para garantizar la seguridad en el uso de los servicios de red.

Guía

Las medidas de seguridad necesarias para servicios particulares, tales como características de seguridad, niveles de servicio y requisitos de servicio, deben ser identificadas e implementadas (por proveedores de servicios de red internos o externos). La organización debe asegurarse de que los proveedores de servicios de red implementen estas medidas.

La capacidad del proveedor de servicios de red para gestionar los servicios acordados de forma segura debe determinarse y controlarse periódicamente. El derecho a la auditoría debe acordarse entre la organización y el proveedor. La organización también debe considerar las certificaciones de terceros proporcionadas por los proveedores de servicios para demostrar que mantienen las medidas de seguridad adecuadas.

Las reglas sobre el uso de redes y servicios de red deben formularse e implementarse para cubrir:

- a) las redes y los servicios de red a los que se permite acceder;
- b) requisitos de autenticación para acceder a diversos servicios de red;
- c) procedimientos de autorización para determinar quién puede acceder a qué redes y servicios en red;

- d) administración de redes y controles tecnológicos y procedimientos para proteger el acceso a conexiones de red y servicios de red;
- e) los medios utilizados para acceder a redes y servicios de red [por ejemplo, uso de red privada virtual (VPN) o red inalámbrica];
- f) hora, ubicación y otros atributos del usuario al momento del acceso;
- g) seguimiento del uso de los servicios de red.

Se deben considerar las siguientes características de seguridad de los servicios de red:

- a) tecnología aplicada para la seguridad de los servicios de red, como autenticación, encriptación y controles de conexión a la red;
- b) parámetros técnicos requeridos para la conexión segura con los servicios de red de acuerdo con las normas de seguridad y conexión a la red;
- c) almacenamiento en caché (por ejemplo, en una red de entrega de contenido) y sus parámetros que permiten a los usuarios elegir el uso del almacenamiento en caché de acuerdo con los requisitos de rendimiento, disponibilidad y confidencialidad;
- d) procedimientos para el uso de servicios de red para restringir el acceso a servicios o aplicaciones de red, cuando sea necesario.

Otra información

Los servicios de red incluyen la provisión de conexiones, servicios de red privada y soluciones de seguridad de red administrada, como firewalls y sistemas de detección de intrusos. Estos servicios pueden variar desde ancho de banda simple no administrado hasta ofertas complejas de valor agregado.

En ISO/IEC 29146 se proporciona más orientación sobre un marco para la gestión de acceso.

8.22 Segregación de redes

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# sistema_y_red- trabajo_seguridad	# Proteccion

Control

Los grupos de servicios de información, usuarios y sistemas de información deben estar segregados en las redes de la organización.

Objetivo

Dividir la red en límites de seguridad y controlar el tráfico entre ellos en función de las necesidades comerciales.

Guía

La organización debería considerar la gestión de la seguridad de las grandes redes dividiéndolas en dominios de red separados y separándolas de la red pública (es decir, Internet). Los dominios se pueden elegir en función de los niveles de confianza, criticidad y sensibilidad (p. ej., dominio de acceso público, dominio de escritorio, dominio de servidor, sistemas de alto y bajo riesgo), junto con unidades organizativas (p. ej., recursos humanos, finanzas, marketing) o alguna combinación. (por ejemplo, dominio del servidor que se conecta a varias unidades organizativas). La segregación se puede realizar usando redes físicamente diferentes o usando diferentes redes lógicas.

El perímetro de cada dominio debe estar bien definido. Si se permite el acceso entre dominios de red, debe controlarse en el perímetro mediante una puerta de enlace (por ejemplo, cortafuegos, enrutador de filtrado). Los criterios para

la segregación de redes en dominios y el acceso permitido a través de las puertas de enlace deben basarse en una evaluación de los requisitos de seguridad de cada dominio. La evaluación debe estar de acuerdo con la política específica del tema sobre el control de acceso (ver [5.15](#)), los requisitos de acceso, el valor y la clasificación de la información procesada y tener en cuenta el coste relativo y el impacto en el rendimiento de la incorporación de una tecnología de puerta de enlace adecuada.

Las redes inalámbricas requieren un tratamiento especial debido al perímetro de red mal definido. Se debe considerar el ajuste de la cobertura de radio para la segregación de redes inalámbricas. Para entornos sensibles, se debe considerar tratar todos los accesos inalámbricos como conexiones externas y segregar este acceso de las redes internas hasta que el acceso haya pasado a través de una puerta de enlace de acuerdo con los controles de la red (ver [8.20](#)) antes de otorgar acceso a los sistemas internos. La red de acceso inalámbrico para invitados debe separarse de las del personal si el personal solo usa dispositivos de punto final de usuario controlados que cumplen con las políticas específicas del tema de la organización. El WiFi para invitados debe tener al menos las mismas restricciones que el WiFi para el personal, a fin de desalentar el uso del WiFi de invitados por parte del personal.

Otra información

Las redes a menudo se extienden más allá de los límites organizacionales, ya que se forman asociaciones comerciales que requieren la interconexión o el intercambio de instalaciones de redes y procesamiento de información. Dichas extensiones pueden aumentar el riesgo de acceso no autorizado a los sistemas de información de la organización que utilizan la red, algunos de los cuales requieren protección de otros usuarios de la red debido a su confidencialidad o criticidad.

8.23 Filtrado web

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# sistema_y_red- trabajo_seguridad	# Proteccion

Control

El acceso a sitios web externos debe administrarse para reducir la exposición a contenido malicioso.

Objetivo

Para proteger los sistemas contra el malware y evitar el acceso a recursos web no autorizados.

Guía

La organización debe reducir los riesgos de que su personal acceda a sitios web que contengan información ilegal o que se sepa que contienen virus o material de phishing. Una técnica para lograr esto funciona bloqueando la dirección IP o el dominio de los sitios web en cuestión. Algunos navegadores y tecnologías antimalware hacen esto automáticamente o pueden configurarse para hacerlo.

La organización debe identificar los tipos de sitios web a los que el personal debe o no tener acceso. La organización debería considerar bloquear el acceso a los siguientes tipos de sitios web:

- a) sitios web que tienen una función de carga de información a menos que esté permitido por razones comerciales válidas;
- b) sitios web maliciosos conocidos o sospechosos (por ejemplo, aquellos que distribuyen malware o contenido de phishing);
- c) servidores de mando y control;
- d) sitio web malicioso adquirido de inteligencia de amenazas (ver [5.7](#));
- e) sitios web que comparten contenido ilegal.

Antes de implementar este control, la organización debe establecer reglas para el uso seguro y apropiado de los recursos en línea, incluida cualquier restricción a sitios web y aplicaciones basadas en la web indeseables o inapropiados. Las reglas deben mantenerse actualizadas.

Se debe brindar capacitación al personal sobre el uso seguro y apropiado de los recursos en línea, incluido el acceso a la web. La capacitación debe incluir las reglas de la organización, el punto de contacto para plantear problemas de seguridad y el proceso de excepción cuando se necesita acceder a recursos web restringidos por razones comerciales legítimas. También se debe capacitar al personal para asegurarse de que no invalide ningún aviso del navegador que informe que un sitio web no es seguro pero permite que el usuario continúe.

Otra información

El filtrado web puede incluir una variedad de técnicas que incluyen firmas, heurística, lista de sitios web o dominios aceptables, lista de sitios web o dominios prohibidos y configuración personalizada para ayudar a evitar que el software malicioso y otras actividades maliciosas ataquen la red y los sistemas de la organización.

8.24 Uso de criptografía

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Seguridad do- red eléctrica
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# configuración_segura	# Proteccion

Control

Deben definirse e implementarse reglas para el uso eficaz de la criptografía, incluida la gestión de claves criptográficas.

Objetivo

Garantizar el uso adecuado y eficaz de la criptografía para proteger la confidencialidad, la autenticidad o la integridad de la información de acuerdo con los requisitos comerciales y de seguridad de la información, y teniendo en cuenta los requisitos legales, estatutarios, reglamentarios y contractuales relacionados con la criptografía.

Guía

General

Al usar criptografía, se debe considerar lo siguiente:

- la política específica del tema sobre criptografía definida por la organización, incluidos los principios generales para la protección de la información. Es necesaria una política específica sobre el uso de la criptografía para maximizar los beneficios y minimizar los riesgos del uso de técnicas criptográficas y para evitar el uso inapropiado o incorrecto;
- identificar el nivel de protección requerido y la clasificación de la información y en consecuencia establecer el tipo, fortaleza y calidad de los algoritmos criptográficos requeridos;
- el uso de criptografía para la protección de la información contenida en los dispositivos móviles o medios de almacenamiento de los usuarios y transmitida a través de redes a dichos dispositivos o medios de almacenamiento;
- el enfoque de la gestión de claves, incluidos los métodos para gestionar la generación y protección de claves criptográficas y la recuperación de información cifrada en caso de pérdida, compromiso o daño de claves;
- roles y responsabilidades para:
 - la implementación de las reglas para el uso efectivo de la criptografía;

- 2) la gestión de claves, incluida la generación de claves (ver [8.24](#));
- f) los estándares a adoptar, así como los algoritmos criptográficos, la fuerza del cifrado, las soluciones criptográficas y las prácticas de uso que se aprueban o requieren para su uso en la organización;
- g) el impacto del uso de información cifrada en los controles que se basan en la inspección de contenido (por ejemplo, detección de malware o filtrado de contenido).

Al implementar las reglas de la organización para el uso eficaz de la criptografía, se deben tener en cuenta las reglamentaciones y las restricciones nacionales que pueden aplicarse al uso de técnicas criptográficas en diferentes partes del mundo, así como los problemas del flujo transfronterizo de información cifrada (ver [5.31](#)).

El contenido de los acuerdos o contratos de nivel de servicio con proveedores externos de servicios criptográficos (por ejemplo, con una autoridad de certificación) debe cubrir cuestiones de responsabilidad, confiabilidad de los servicios y tiempos de respuesta para la prestación de servicios (ver [5.22](#)).

Gestión de claves

La gestión adecuada de claves requiere procesos seguros para generar, almacenar, archivar, recuperar, distribuir, retirar y destruir claves criptográficas.

Un sistema de gestión de claves debe basarse en un conjunto acordado de normas, procedimientos y métodos seguros para:

- a) generar claves para diferentes sistemas criptográficos y diferentes aplicaciones;
- b) emitir y obtener certificados de clave pública;
- c) distribuir claves a las entidades previstas, incluido cómo activar las claves cuando se reciben;
- d) almacenar claves, incluida la forma en que los usuarios autorizados obtienen acceso a las claves;
- e) cambiar o actualizar las claves, incluidas las reglas sobre cuándo cambiar las claves y cómo se hará;
- f) tratar con claves comprometidas;
- g) revocación de claves, incluido cómo retirar o desactivar claves [por ejemplo, cuando las claves se han visto comprometidas o cuando un usuario abandona una organización (en cuyo caso, las claves también deben archivar)];
- h) recuperar claves perdidas o corruptas;
- i) realizar copias de seguridad o archivar claves;
- j) destrucción de llaves;
- k) registro y auditoría de actividades clave relacionadas con la gestión;
- l) establecer fechas de activación y desactivación de claves para que las claves solo se puedan usar durante el período de tiempo de acuerdo con las reglas de la organización sobre administración de claves;
- m) tramitar solicitudes legales de acceso a claves criptográficas (p. ej., se puede exigir que la información cifrada esté disponible sin cifrar como prueba en un caso judicial).

Todas las claves criptográficas deben protegerse contra modificaciones y pérdidas. Además, las claves secretas y privadas necesitan protección contra el uso no autorizado y la divulgación. El equipo utilizado para generar, almacenar y archivar claves debe protegerse físicamente.

Además de la integridad, para muchos casos de uso, también se debe considerar la autenticidad de las claves públicas.

Otra información

La autenticidad de las claves públicas generalmente se aborda mediante procesos de administración de claves públicas que utilizan autoridades de certificación y certificados de clave pública, pero también es posible abordarla mediante el uso de tecnologías como la aplicación de procesos manuales para claves de números pequeños.

La criptografía se puede utilizar para lograr diferentes objetivos de seguridad de la información, por ejemplo:

- a) confidencialidad: uso de cifrado de información para proteger información sensible o crítica, ya sea almacenada o transmitida;
- b) integridad o autenticidad: uso de firmas digitales o códigos de autenticación de mensajes para verificar la autenticidad o integridad de la información sensible o crítica almacenada o transmitida. Usar algoritmos con el fin de verificar la integridad de los archivos;
- c) no repudio: uso de técnicas criptográficas para proporcionar evidencia de la ocurrencia o no ocurrencia de un evento o acción;
- d) autenticación: uso de técnicas criptográficas para autenticar usuarios y otras entidades del sistema que solicitan acceso o realizan transacciones con usuarios, entidades y recursos del sistema.

La serie ISO/IEC 11770 proporciona más información sobre la gestión de claves.

8.25 Ciclo de vida de desarrollo seguro

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#Aplicación_seguridad # sistema_y_red- trabajo_seguridad	# Proteccion

Control

Deben establecerse y aplicarse reglas para el desarrollo seguro de software y sistemas.

Objetivo

Garantizar que la seguridad de la información se diseñe e implemente dentro del ciclo de vida de desarrollo seguro de software y sistemas.

Guía

El desarrollo seguro es un requisito para crear un servicio, una arquitectura, un software y un sistema seguros. Para lograrlo, se deben considerar los siguientes aspectos:

- a) separación de los entornos de desarrollo, prueba y producción (ver [8.31](#));
- b) orientación sobre la seguridad en el ciclo de vida del desarrollo de software:
 - 1) seguridad en la metodología de desarrollo de software (ver [8.28](#) y [8.27](#));
 - 2) pautas de codificación segura para cada lenguaje de programación utilizado (ver [8.28](#));
- c) requisitos de seguridad en la fase de especificación y diseño (ver [5.8](#));
- d) puntos de control de seguridad en proyectos (ver [5.8](#));
- e) pruebas de sistema y seguridad, como pruebas de regresión, escaneo de código y pruebas de penetración (ver [8.29](#));
- f) repositorios seguros para el código fuente y la configuración (ver [8.4](#) y [8.9](#));
- g) seguridad en el control de versiones (ver [8.32](#));

- h) conocimiento y capacitación en seguridad de la aplicación requeridos (ver [8.28](#));
- i) la capacidad de los desarrolladores para prevenir, encontrar y reparar vulnerabilidades (ver [8.28](#));
- j) requisitos de licencia y alternativas para garantizar soluciones rentables y evitar futuros problemas de licencia (ver [5.32](#)).

Si se subcontrata el desarrollo, la organización debe asegurarse de que el proveedor cumpla con las reglas de la organización para el desarrollo seguro (ver [8.30](#)).

Otra información

El desarrollo también puede tener lugar dentro de aplicaciones, como aplicaciones de oficina, secuencias de comandos, navegadores y bases de datos.

8.26 Requisitos de seguridad de la aplicación

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#Aplicación_seguridad # sistema_y_red- trabajo_seguridad	# Proteccion # Defensa

Control

Los requisitos de seguridad de la información deben identificarse, especificarse y aprobarse al desarrollar o adquirir aplicaciones.

Objetivo

Para garantizar que todos los requisitos de seguridad de la información se identifiquen y aborden al desarrollar o adquirir aplicaciones.

Guía

General

Deben identificarse y especificarse los requisitos de seguridad de las aplicaciones. Estos requisitos generalmente se determinan a través de una evaluación de riesgos. Los requisitos deben desarrollarse con el apoyo de especialistas en seguridad de la información.

Los requisitos de seguridad de la aplicación pueden cubrir una amplia gama de temas, según el propósito de la aplicación.

Los requisitos de seguridad de la aplicación deben incluir, según corresponda:

- a) nivel de confianza en la identidad de las entidades [por ejemplo, a través de la autenticación (ver [5.17](#), [8.2](#) y [8.5](#))];
- b) identificar el tipo de información y el nivel de clasificación a ser procesado por la aplicación;
- c) necesidad de segregación de acceso y nivel de acceso a datos y funciones en la aplicación;
- d) resiliencia contra ataques maliciosos o interrupciones no intencionales [por ejemplo, protección contra desbordamiento de búfer o inyecciones de lenguaje de consulta estructurado (SQL)];
- e) requisitos legales, estatutarios y reglamentarios en la jurisdicción donde se genera, procesa, completa o almacena la transacción;
- f) necesidad de privacidad asociada con todas las partes involucradas;
- g) los requisitos de protección de cualquier información confidencial;
- h) protección de datos en proceso, en tránsito y en reposo;

- i) necesidad de cifrar de forma segura las comunicaciones entre todas las partes involucradas;
- j) controles de entrada, incluidas verificaciones de integridad y validación de entrada;
- k) controles automatizados (por ejemplo, límites de aprobación o aprobaciones duales);
- l) controles de salida, considerando también quién puede acceder a las salidas y su autorización;
- m) restricciones en torno al contenido de los campos de "texto libre", ya que pueden conducir al almacenamiento no controlado de datos confidenciales (por ejemplo, datos personales);
- n) requisitos derivados del proceso de negocio, tales como registro y seguimiento de transacciones, requisitos de no repudio;
- o) requisitos exigidos por otros controles de seguridad (por ejemplo, interfaces para registro y monitoreo o sistemas de detección de fuga de datos);
- p) manejo de mensajes de error.

Servicios transaccionales

Además, para las aplicaciones que ofrecen servicios transaccionales entre la organización y un socio, se debe considerar lo siguiente al identificar los requisitos de seguridad de la información:

- a) el nivel de confianza que cada parte requiere en la identidad reclamada de la otra parte;
- b) el nivel de confianza requerido en la integridad de la información intercambiada o procesada y los mecanismos para la identificación de la falta de integridad (por ejemplo, verificación de redundancia cíclica, hashing, firmas digitales);
- c) procesos de autorización asociados con quién puede aprobar contenidos, emitir o firmar documentos transaccionales clave;
- d) confidencialidad, integridad, prueba de envío y recepción de documentos clave y no repudio (por ejemplo, contratos asociados a procesos de licitación y contratación);
- e) la confidencialidad e integridad de cualquier transacción (por ejemplo, pedidos, detalles de la dirección de entrega y confirmación de recibos);
- f) requisitos sobre cuánto tiempo mantener la confidencialidad de una transacción;
- g) seguros y otros requisitos contractuales.

Aplicaciones de pago y pedidos electrónicos

Además, para aplicaciones que involucren pedidos y pagos electrónicos, se debe considerar lo siguiente:

- a) requisitos para mantener la confidencialidad e integridad de la información de la orden;
- b) el grado de verificación apropiado para verificar la información de pago proporcionada por un cliente;
- c) evitar la pérdida o duplicación de información de transacciones;
- d) almacenar los detalles de la transacción fuera de cualquier entorno de acceso público (p. ej., en una plataforma de almacenamiento existente en la intranet de la organización, y no retenida ni expuesta en medios de almacenamiento electrónico directamente accesibles desde Internet);
- e) cuando se utiliza una autoridad de confianza (p. ej., con el fin de emitir y mantener firmas digitales o certificados digitales), la seguridad se integra y se incorpora a lo largo de todo el proceso de gestión de firmas o certificados de extremo a extremo.

Varias de las consideraciones anteriores pueden abordarse mediante la aplicación de la criptografía (ver [8.24](#)), teniendo en cuenta los requisitos legales (ver [5.31](#) a [5.36](#), especialmente ver [5.31](#) para la legislación criptográfica).

Otra información

Las aplicaciones accesibles a través de las redes están sujetas a una variedad de amenazas relacionadas con la red, como actividades fraudulentas, disputas de contratos o divulgación de información al público; transmisión incompleta, enrutamiento erróneo, alteración no autorizada de mensajes, duplicación o reproducción. Por lo tanto, las evaluaciones de riesgo detalladas y la determinación cuidadosa de los controles son indispensables. Los controles requeridos a menudo incluyen métodos criptográficos para la autenticación y la seguridad de la transferencia de datos.

Puede encontrar más información sobre la seguridad de las aplicaciones en la serie ISO/IEC 27034.

8.27 Arquitectura del sistema seguro y principios de ingeniería

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#Aplicación_seguridad # sistema_y_red- trabajo_seguridad	# Proteccion

Control

Los principios para diseñar sistemas seguros deben establecerse, documentarse, mantenerse y aplicarse a cualquier actividad de desarrollo de sistemas de información.

Objetivo

Garantizar que los sistemas de información se diseñen, implementen y operen de forma segura dentro del ciclo de vida del desarrollo.

Guía

Los principios de ingeniería de seguridad deben establecerse, documentarse y aplicarse a las actividades de ingeniería de sistemas de información. La seguridad debe diseñarse en todas las capas de la arquitectura (negocios, datos, aplicaciones y tecnología). La nueva tecnología debe analizarse en busca de riesgos de seguridad y el diseño debe revisarse frente a patrones de ataque conocidos.

Los principios de ingeniería segura brindan orientación sobre las técnicas de autenticación de usuarios, el control seguro de sesiones y la validación y desinfección de datos.

Los principios de ingeniería de sistemas seguros deben incluir el análisis de:

- la gama completa de controles de seguridad necesarios para proteger la información y los sistemas contra las amenazas identificadas;
- las capacidades de los controles de seguridad para prevenir, detectar o responder a eventos de seguridad;
- controles de seguridad específicos requeridos por procesos comerciales particulares (por ejemplo, encriptación de información confidencial, verificación de integridad y firma digital de información);
- dónde y cómo se aplicarán los controles de seguridad (p. ej., mediante la integración con una arquitectura de seguridad y la infraestructura técnica);
- cómo los controles de seguridad individuales (manuales y automatizados) funcionan juntos para producir un conjunto integrado de controles.

Los principios de ingeniería de seguridad deberían tener en cuenta:

- la necesidad de integrarse con una arquitectura de seguridad;

- b) infraestructura de seguridad técnica [por ejemplo, infraestructura de clave pública (PKI), gestión de acceso e identidad (IAM), prevención de fuga de datos y gestión de acceso dinámico];
- c) capacidad de la organización para desarrollar y soportar la tecnología elegida;
- d) costo, tiempo y complejidad de cumplir con los requisitos de seguridad;
- e) buenas prácticas actuales.

La ingeniería de sistemas seguros debe implicar:

- a) el uso de principios de arquitectura de seguridad, tales como "seguridad por diseño", "defensa en profundidad", "seguridad por defecto", "denegación predeterminada", "fallo seguro", "desconfiar de la entrada de aplicaciones externas", "seguridad en implementación", "asumir incumplimiento", "privilegio mínimo", "facilidad de uso y administración" y "funcionalidad mínima";
- b) una revisión del diseño orientada a la seguridad para ayudar a identificar las vulnerabilidades de la seguridad de la información, asegurar que se especifiquen los controles de seguridad y cumplir con los requisitos de seguridad;
- c) documentación y reconocimiento formal de los controles de seguridad que no cumplen plenamente los requisitos (por ejemplo, debido a requisitos de seguridad superiores);
- d) endurecimiento de los sistemas.

La organización debe considerar principios de "confianza cero" tales como:

- a) suponiendo que los sistemas de información de la organización ya están violados y, por lo tanto, no dependen solo de la seguridad del perímetro de la red;
- b) emplear un enfoque de "nunca confiar y siempre verificar" para el acceso a los sistemas de información;
- c) garantizar que las solicitudes a los sistemas de información estén encriptadas de extremo a extremo;
- d) verificar cada solicitud a un sistema de información como si se originara en una red externa abierta, incluso si estas solicitudes se originaron internamente en la organización (es decir, no confiar automáticamente en nada dentro o fuera de sus perímetros);
- e) usar técnicas de control de acceso dinámico y de "privilegio mínimo" (ver [5.15](#), [5.18](#) y [8.2](#)). Esto incluye autenticar y autorizar solicitudes de información o a sistemas basados en información contextual, como información de autenticación (ver [5.17](#)), identidades de usuario (ver [5.16](#)), datos sobre el dispositivo de punto final del usuario y clasificación de datos (ver [5.12](#));
- f) siempre autenticando a los solicitantes y siempre validando las solicitudes de autorización a los sistemas de información en base a la información, incluida la información de autenticación (ver [5.17](#)) e identidades de usuario ([5.16](#)), datos sobre el dispositivo de punto final del usuario y clasificación de datos (ver [5.12](#)), por ejemplo, hacer cumplir una autenticación sólida (por ejemplo, multifactor, consulte [8.5](#)).

Los principios de ingeniería de seguridad establecidos deben aplicarse, cuando corresponda, al desarrollo subcontratado de sistemas de información a través de contratos y otros acuerdos vinculantes entre la organización y el proveedor a quien la organización subcontrata. La organización debe garantizar que las prácticas de ingeniería de seguridad de los proveedores se alineen con las necesidades de la organización.

Los principios de ingeniería de seguridad y los procedimientos de ingeniería establecidos deben revisarse periódicamente para garantizar que contribuyan efectivamente a mejorar los estándares de seguridad dentro del proceso de ingeniería. También deben revisarse periódicamente para garantizar que permanezcan actualizados en términos de combatir cualquier nueva amenaza potencial y seguir siendo aplicables a los avances en las tecnologías y soluciones que se aplican.

Otra información

Los principios de ingeniería segura se pueden aplicar al diseño o configuración de una variedad de técnicas, como:

- tolerancia a fallas y otras técnicas de resiliencia;
- segregación (p. ej., mediante virtualización o contenedorización);
- resistencia a la manipulación.

Se pueden utilizar técnicas de virtualización seguras para evitar la interferencia entre aplicaciones que se ejecutan en el mismo dispositivo físico. Si un atacante pone en peligro una instancia virtual de una aplicación, solo esa instancia se ve afectada. El ataque no tiene efecto en ninguna otra aplicación o datos.

Las técnicas de resistencia a la manipulación pueden utilizarse para detectar la manipulación de contenedores de información, ya sea física (p. ej., una alarma antirrobo) o lógica (p. ej., un archivo de datos). Una característica de tales técnicas es que existe un registro del intento de manipulación del contenedor. Además, el control puede impedir la correcta extracción de datos mediante su destrucción (p. ej., se puede borrar la memoria del dispositivo).

8.28 Codificación segura

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Seguridad do- red eléctrica
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#Aplicación_seguridad # Sistema_y_red_ seguridad	# Proteccion

Control

Los principios de codificación segura deben aplicarse al desarrollo de software.

Objetivo

Garantizar que el software se escriba de forma segura, reduciendo así la cantidad de posibles vulnerabilidades de seguridad de la información en el software.

Guía

General

La organización debe establecer procesos en toda la organización para proporcionar una buena gobernanza para la codificación segura. Se debe establecer y aplicar una línea de base segura mínima. Además, dichos procesos y gobernanza deben extenderse para cubrir los componentes de software de terceros y el software de código abierto.

La organización debe monitorear las amenazas del mundo real y actualizar el asesoramiento y la información sobre las vulnerabilidades del software para guiar los principios de codificación segura de la organización a través de la mejora y el aprendizaje continuos. Esto puede ayudar a garantizar que se implementen prácticas de codificación seguras y efectivas para combatir el panorama de amenazas que cambia rápidamente.

Planificación y antes de codificar

Los principios de codificación segura deben usarse tanto para nuevos desarrollos como en escenarios de reutilización. Estos principios deben aplicarse a las actividades de desarrollo tanto dentro de la organización como para los productos y servicios que la organización proporciona a otros. La planificación y los requisitos previos antes de la codificación deben incluir:

- a) expectativas específicas de la organización y principios aprobados para la codificación segura que se utilizará para desarrollos de código internos y externos;
- b) prácticas y defectos de codificación comunes e históricos que conducen a vulnerabilidades de seguridad de la información;

- c) configurar herramientas de desarrollo, como entornos de desarrollo integrados (IDE), para ayudar a hacer cumplir la creación de código seguro;
- d) seguir la orientación emitida por los proveedores de herramientas de desarrollo y entornos de ejecución, según corresponda;
- e) mantenimiento y uso de herramientas de desarrollo actualizadas (por ejemplo, compiladores);
- f) calificación de los desarrolladores en la escritura de código seguro;
- g) diseño y arquitectura seguros, incluido el modelado de amenazas;
- h) normas de codificación seguras y, cuando corresponda, exigir su uso;
- i) uso de ambientes controlados para el desarrollo.

Durante la codificación

Las consideraciones durante la codificación deben incluir:

- a) prácticas de codificación seguras específicas para los lenguajes y técnicas de programación que se utilizan;
- b) utilizar técnicas de programación seguras, como programación en pares, refactorización, revisión por pares, iteraciones de seguridad y desarrollo basado en pruebas;
- c) utilizando técnicas de programación estructurada;
- d) documentar el código y eliminar los defectos de programación, lo que puede permitir que se exploten las vulnerabilidades de seguridad de la información;
- e) prohibir el uso de técnicas de diseño inseguras (por ejemplo, el uso de contraseñas codificadas, ejemplos de código no aprobados y servicios web no autenticados).

Las pruebas deben realizarse durante y después del desarrollo (ver [8.29](#)). Los procesos de prueba de seguridad de aplicaciones estáticas (SAST) pueden identificar vulnerabilidades de seguridad en el software.

Antes de que el software entre en funcionamiento, se debe evaluar lo siguiente:

- a) superficie de ataque y el principio de privilegio mínimo;
- b) realizar un análisis de los errores de programación más comunes y documentar que estos han sido mitigados.

Revisión y mantenimiento

Después de que el código se haya hecho operativo:

- a) las actualizaciones deben empaquetarse e implementarse de forma segura;
- b) se deben manejar las vulnerabilidades de seguridad de la información informadas (ver [8.8](#));
- c) los errores y los ataques sospechosos deben registrarse y los registros deben revisarse periódicamente para hacer los ajustes necesarios al código;
- d) el código fuente debe protegerse contra el acceso no autorizado y la manipulación (p. ej., mediante el uso de herramientas de gestión de la configuración, que suelen proporcionar funciones como control de acceso y control de versiones).

Si utiliza herramientas y bibliotecas externas, la organización debe considerar:

- a) garantizar que las bibliotecas externas se gestionen (p. ej., manteniendo un inventario de las bibliotecas utilizadas y sus versiones) y se actualicen periódicamente con los ciclos de publicación;

- b) selección, autorización y reutilización de componentes bien examinados, en particular componentes de autenticación y criptográficos;
- c) la licencia, seguridad e historial de los componentes externos;
- d) garantizar que el software se pueda mantener, rastrear y provenir de fuentes comprobadas y confiables;
- e) disponibilidad a largo plazo de recursos y artefactos para el desarrollo.

Cuando sea necesario modificar un paquete de software, se deben considerar los siguientes puntos:

- a) el riesgo de que los controles incorporados y los procesos de integridad se vean comprometidos;
- b) si se debe obtener el consentimiento del vendedor;
- c) la posibilidad de obtener los cambios necesarios del proveedor como actualizaciones estándar del programa;
- d) el impacto si la organización se hace responsable del mantenimiento futuro del software como resultado de los cambios;
- e) compatibilidad con otro software en uso.

Otra información

Un principio rector es garantizar que el código relevante para la seguridad se invoque cuando sea necesario y sea resistente a la manipulación. Los programas instalados a partir de código binario compilado también tienen estas propiedades, pero solo para los datos contenidos en la aplicación. Para los lenguajes interpretados, el concepto solo funciona cuando el código se ejecuta en un servidor que de otro modo es inaccesible para los usuarios y los procesos que lo usan, y que sus datos se mantienen en una base de datos protegida de manera similar. Por ejemplo, el código interpretado se puede ejecutar en un servicio en la nube donde el acceso al código requiere privilegios de administrador. Dicho acceso de administrador debe estar protegido por mecanismos de seguridad, como los principios de administración justo a tiempo y la autenticación fuerte. Si el propietario de la aplicación puede acceder a los scripts mediante acceso remoto directo al servidor, en principio también puede hacerlo un atacante.

El código de la aplicación se diseña mejor asumiendo que siempre está sujeto a ataques, por error o acción maliciosa. Además, las aplicaciones críticas pueden diseñarse para ser tolerantes a fallas internas. Por ejemplo, la salida de un algoritmo complejo puede verificarse para asegurarse de que se encuentra dentro de límites seguros antes de que los datos se utilicen en una aplicación como una aplicación crítica financiera o de seguridad. El código que realiza las comprobaciones de límites es simple y, por lo tanto, mucho más fácil de probar que es correcto.

Algunas aplicaciones web son susceptibles a una variedad de vulnerabilidades que son introducidas por un diseño y una codificación deficientes, como la inyección de bases de datos y los ataques de secuencias de comandos entre sitios. En estos ataques, las solicitudes pueden manipularse para abusar de la funcionalidad del servidor web.

Puede encontrar más información sobre la evaluación de la seguridad de las TIC en la serie ISO/IEC 15408.

8.29 Pruebas de seguridad en desarrollo y aceptación

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	#Aplicación_seguridad # Information_security_assurance # sistema_y_red-trabajo_seguridad	# Protección

Control

Los procesos de prueba de seguridad deben definirse e implementarse en el ciclo de vida del desarrollo.

Objetivo

Para validar si se cumplen los requisitos de seguridad de la información cuando las aplicaciones o el código se implementan en el entorno de producción.

Guía

Los nuevos sistemas de información, las actualizaciones y las nuevas versiones deben probarse y verificarse minuciosamente durante los procesos de desarrollo. Las pruebas de seguridad deben ser una parte integral de las pruebas de sistemas o componentes.

Las pruebas de seguridad deben realizarse frente a un conjunto de requisitos, que pueden expresarse como funcionales o no funcionales. Las pruebas de seguridad deben incluir pruebas de:

- a) funciones de seguridad [por ejemplo, autenticación de usuario (ver [8.5](#)), restricción de acceso (ver [8.3](#)) y el uso de la criptografía (ver [8.24](#))];
- b) codificación segura (ver [8.28](#));
- c) configuraciones seguras (ver [8.9](#), [8.20](#) y [8.22](#)) incluido el de los sistemas operativos, cortafuegos y otros componentes de seguridad.

Los planes de prueba deben determinarse utilizando un conjunto de criterios. El alcance de las pruebas debe ser proporcional a la importancia, la naturaleza del sistema y el impacto potencial del cambio que se está introduciendo. El plan de prueba debe incluir:

- a) cronograma detallado de actividades y pruebas;
- b) insumos y productos esperados bajo una variedad de condiciones;
- c) criterios para evaluar los resultados;
- d) decisión de acciones adicionales según sea necesario.

La organización puede aprovechar las herramientas automatizadas, como las herramientas de análisis de código o los escáneres de vulnerabilidades, y debe verificar la corrección de los defectos relacionados con la seguridad.

Para los desarrollos internos, estas pruebas deben ser realizadas inicialmente por el equipo de desarrollo. Luego, se deben realizar pruebas de aceptación independientes para garantizar que el sistema funcione como se espera y solo como se espera (ver [5.8](#)). Se debe considerar lo siguiente:

- a) realizar actividades de revisión de código como un elemento relevante para probar fallas de seguridad, incluidas entradas y condiciones no anticipadas;
- b) realizar un escaneo de vulnerabilidades para identificar configuraciones inseguras y vulnerabilidades del sistema;
- c) realizar pruebas de penetración para identificar código y diseño inseguros.

Para los componentes de compra y desarrollo subcontratados, se debe seguir un proceso de adquisición. Los contratos con el proveedor deben abordar los requisitos de seguridad identificados (ver [5.20](#)). Los productos y servicios deben evaluarse según estos criterios antes de la adquisición.

Las pruebas deben realizarse en un entorno de prueba que coincida lo más posible con el entorno de producción de destino para garantizar que el sistema no presente vulnerabilidades en el entorno de la organización y que las pruebas sean confiables (ver [8.31](#)).

Otra información

Se pueden establecer varios entornos de prueba, que se pueden utilizar para diferentes tipos de pruebas (por ejemplo, pruebas funcionales y de rendimiento). Estos diferentes entornos pueden ser virtuales, con configuraciones individuales para simular una variedad de entornos operativos.

También se deben considerar las pruebas y el monitoreo de los entornos de prueba, las herramientas y las tecnologías para garantizar la eficacia de las pruebas. Las mismas consideraciones se aplican al monitoreo de los sistemas de monitoreo implementados en entornos de desarrollo, prueba y producción. Se necesita juicio, guiado por la sensibilidad de los sistemas y los datos, para determinar cuántas capas de meta-test son útiles.

8.30 Desarrollo subcontratado

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo # Detective	# Confidencialidad # Integridad # Disponibilidad	# Identificar # Proteger # Detectar	# Sistema_y_red_ seguridad #Aplicación_seguridad #Proveedores_relaciones_seguridad	# Gobernanza_y_ Ecosistema # Proteccion

Control

La organización debe dirigir, monitorear y revisar las actividades relacionadas con el desarrollo de sistemas subcontratados.

Objetivo

Para garantizar que las medidas de seguridad de la información requeridas por la organización se implementen en el desarrollo de sistemas subcontratados.

Guía

Cuando se subcontrata el desarrollo del sistema, la organización debe comunicar y acordar los requisitos y expectativas, y monitorear y revisar continuamente si la entrega del trabajo subcontratado cumple con estas expectativas. Se deben considerar los siguientes puntos en toda la cadena de suministro externa de la organización:

- a) acuerdos de licencia, propiedad del código y derechos de propiedad intelectual relacionados con el contenido subcontratado (ver [5.32](#));
- b) requisitos contractuales para prácticas seguras de diseño, codificación y prueba (ver [8.25](#) a [8.29](#));
- c) provisión del modelo de amenaza a considerar por desarrolladores externos;
- d) pruebas de aceptación de la calidad y precisión de los entregables (ver [8.29](#));
- e) suministro de pruebas de que se han establecido los niveles mínimos aceptables de seguridad y capacidades de privacidad (p. ej., informes de garantía);
- f) provisión de evidencia de que se han aplicado suficientes pruebas para protegerse contra la presencia de contenido malicioso (tanto intencional como no intencional) en el momento de la entrega;
- g) provisión de evidencia de que se han aplicado pruebas suficientes para protegerse contra la presencia de vulnerabilidades conocidas;
- h) acuerdos de depósito en garantía para el código fuente del software (por ejemplo, si el proveedor cierra);
- i) derecho contractual a auditar procesos y controles de desarrollo;
- j) requisitos de seguridad para el entorno de desarrollo (ver [8.31](#));
- k) teniendo en cuenta la legislación aplicable (por ejemplo, sobre protección de datos personales).

Otra información

Se puede encontrar más información sobre las relaciones con los proveedores en la serie ISO/IEC 27036.

8.31 Separación de los entornos de desarrollo, prueba y producción

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#Aplicación_seguridad # sistema_y_red- trabajo_seguridad	# Proteccion

Control

Los entornos de desarrollo, prueba y producción deben estar separados y protegidos.

Objetivo

Para proteger el entorno de producción y los datos contra el compromiso de las actividades de desarrollo y prueba.

Guía

Debe identificarse e implementarse el nivel de separación entre los entornos de producción, prueba y desarrollo que es necesario para evitar problemas de producción.

Se deben considerar los siguientes elementos:

- separar adecuadamente los sistemas de desarrollo y producción y operarlos en diferentes dominios (por ejemplo, en entornos físicos o virtuales separados);
- definir, documentar e implementar reglas y autorizaciones para el despliegue de software desde el estado de desarrollo hasta el de producción;
- probar los cambios en los sistemas de producción y las aplicaciones en un entorno de prueba o ensayo antes de aplicarlos a los sistemas de producción (ver [8.29](#));
- no realizar pruebas en entornos de producción excepto en circunstancias que hayan sido definidas y aprobadas;
- compiladores, editores y otras herramientas de desarrollo o programas de utilidad que no sean accesibles desde los sistemas de producción cuando no se requieran;
- mostrar etiquetas de identificación del entorno adecuadas en los menús para reducir el riesgo de error;
- no copiar información confidencial en los entornos del sistema de desarrollo y prueba a menos que se proporcionen controles equivalentes para los sistemas de desarrollo y prueba.

En todos los casos, los entornos de desarrollo y pruebas deben protegerse teniendo en cuenta:

- aplicación de parches y actualización de todas las herramientas de desarrollo, integración y prueba (incluidos constructores, integradores, compiladores, sistemas de configuración y bibliotecas);
- configuración segura de sistemas y software;
- control de acceso a los ambientes;
- seguimiento de cambios en el entorno y código almacenado en el mismo;
- monitoreo seguro de los ambientes;
- realizar copias de seguridad de los entornos.

Una sola persona no debe tener la capacidad de realizar cambios tanto en el desarrollo como en la producción sin una revisión y aprobación previas. Esto se puede lograr, por ejemplo, mediante la segregación de los derechos de acceso o mediante reglas supervisadas. En situaciones excepcionales, se deben implementar medidas adicionales como registro detallado y monitoreo en tiempo real para detectar y actuar sobre cambios no autorizados.

Otra información

Sin medidas y procedimientos adecuados, los desarrolladores y probadores que tienen acceso a los sistemas de producción pueden presentar riesgos significativos (por ejemplo, modificación no deseada de los archivos o del entorno del sistema, falla del sistema, ejecución de código no autorizado y no probado en los sistemas de producción, divulgación de datos confidenciales, integridad de datos y problemas de disponibilidad). Es necesario mantener un entorno conocido y estable en el que realizar pruebas significativas y evitar el acceso inapropiado del desarrollador al entorno de producción.

Las medidas y los procedimientos incluyen roles cuidadosamente diseñados junto con la implementación de requisitos de segregación de tareas y la implementación de procesos de monitoreo adecuados.

El personal de desarrollo y pruebas también representa una amenaza para la confidencialidad de la información de producción. Las actividades de desarrollo y prueba pueden provocar cambios no deseados en el software o la información si comparten el mismo entorno informático. Por lo tanto, es deseable separar los entornos de desarrollo, prueba y producción para reducir el riesgo de cambios accidentales o acceso no autorizado al software de producción y los datos comerciales (ver [8.33](#) para la protección de la información de prueba).

En algunos casos, la distinción entre entornos de desarrollo, prueba y producción puede desdibujarse deliberadamente y las pruebas pueden llevarse a cabo en un entorno de desarrollo oa través de implementaciones controladas para usuarios o servidores reales (por ejemplo, una pequeña población de usuarios piloto). En algunos casos, la prueba del producto puede ocurrir mediante el uso en vivo del producto dentro de la organización. Además, para reducir el tiempo de inactividad de las implementaciones en vivo, se pueden admitir dos entornos de producción idénticos donde solo uno está en vivo en cualquier momento.

Procesos de soporte para el uso de datos de producción en entornos de desarrollo y prueba ([8.33](#)) son necesarios.

Las organizaciones también pueden considerar la orientación proporcionada en esta sección para los entornos de capacitación al realizar la capacitación del usuario final.

8.32 Gestión de cambios

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#Aplicación_seguridad # sistema_y_red- trabajo_seguridad	# Proteccion

Control

Los cambios en las instalaciones de procesamiento de información y los sistemas de información deben estar sujetos a procedimientos de gestión de cambios.

Objetivo

Preservar la seguridad de la información al ejecutar cambios.

Guía

La introducción de nuevos sistemas y cambios importantes en los sistemas existentes debe seguir reglas acordadas y un proceso formal de documentación, especificación, prueba, control de calidad e implementación administrada. Deben existir responsabilidades y procedimientos de gestión para garantizar un control satisfactorio de todos los cambios.

Los procedimientos de control de cambios deben documentarse y aplicarse para garantizar la confidencialidad, integridad y disponibilidad de la información en las instalaciones de procesamiento de información y los sistemas de información, durante todo el ciclo de vida del desarrollo del sistema, desde las primeras etapas de diseño hasta todos los esfuerzos de mantenimiento posteriores.

Siempre que sea factible, deben integrarse los procedimientos de control de cambios para la infraestructura y el software de las TIC.

Los procedimientos de control de cambios deben incluir:

- a) planificar y evaluar el impacto potencial de los cambios considerando todas las dependencias;
- b) autorización de cambios;
- c) comunicar los cambios a las partes interesadas pertinentes;
- d) pruebas y aceptación de pruebas para los cambios (ver [8.29](#));
- e) implementación de cambios, incluidos los planes de implementación;
- f) consideraciones de emergencia y contingencia, incluidos los procedimientos de respaldo;
- g) mantener registros de cambios que incluyan todo lo anterior;
- h) asegurar que la documentación operativa (ver [5.37](#)) y los procedimientos de usuario se modifican según sea necesario para seguir siendo apropiados;
- i) asegurar que los planes de continuidad de las TIC y los procedimientos de respuesta y recuperación (ver [5.30](#)) se modifican según sea necesario para seguir siendo apropiados.

Otra información

El control inadecuado de los cambios en las instalaciones de procesamiento de información y los sistemas de información es una causa común de fallas en el sistema o la seguridad. Los cambios en el entorno de producción, especialmente cuando se transfiere software del entorno de desarrollo al operativo, pueden afectar la integridad y disponibilidad de las aplicaciones.

Cambiar el software puede afectar el entorno de producción y viceversa.

Las buenas prácticas incluyen la prueba de los componentes de las TIC en un entorno segregado de los entornos de producción y desarrollo (ver [8.31](#)). Esto proporciona un medio para tener control sobre el nuevo software y permitir una protección adicional de la información operativa que se utiliza con fines de prueba. Esto debería incluir parches, paquetes de servicio y otras actualizaciones.

El entorno de producción incluye sistemas operativos, bases de datos y plataformas de middleware. El control debe aplicarse para cambios de aplicaciones e infraestructuras.

8.33 Información de prueba

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad	# Proteger	# Información_protección	# Protección

Control

La información de las pruebas debe seleccionarse, protegerse y gestionarse adecuadamente.

Objetivo

Para garantizar la relevancia de las pruebas y la protección de la información operativa utilizada para las pruebas.

Guía

La información de prueba debe seleccionarse para garantizar la confiabilidad de los resultados de las pruebas y la confidencialidad de la información operativa relevante. La información confidencial (incluida la información de identificación personal) no debe copiarse en los entornos de desarrollo y prueba (consulte [8.31](#)).

Se deben aplicar las siguientes pautas para proteger las copias de la información operativa, cuando se utilizan con fines de prueba, ya sea que el entorno de prueba se construya internamente o en un servicio en la nube:

- a) aplicar los mismos procedimientos de control de acceso a los entornos de prueba que los que se aplican a los entornos operativos;
- b) tener una autorización separada cada vez que se copia información operativa a un entorno de prueba;
- c) registrar la copia y el uso de información operativa para proporcionar una pista de auditoría;
- d) proteger la información confidencial mediante su eliminación o enmascaramiento (ver [8.11](#)) si se utiliza para pruebas;
- e) eliminar correctamente (ver [8.10](#)) información operativa de un entorno de prueba inmediatamente después de que se complete la prueba para evitar el uso no autorizado de la información de la prueba.

La información de la prueba debe almacenarse de forma segura (para evitar la manipulación, que de lo contrario puede generar resultados no válidos) y solo debe usarse para fines de prueba.

Otra información

Las pruebas del sistema y de aceptación pueden requerir volúmenes sustanciales de información de prueba que estén lo más cerca posible de la información operativa.

8.34 Protección de los sistemas de información durante las pruebas de auditoría

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Sistema_y_red_ seguridad # Información_protección	# Gobernanza_y_ Ecosistema #Protec- ción

Control

Las pruebas de auditoría y otras actividades de aseguramiento que involucren la evaluación de los sistemas operativos deben planificarse y acordarse entre el evaluador y la gerencia correspondiente.

Objetivo

Minimizar el impacto de la auditoría y otras actividades de aseguramiento en los sistemas operativos y procesos comerciales.

Guía

Se deben observar las siguientes pautas:

- a) acordar solicitudes de auditoría para el acceso a sistemas y datos con la gestión adecuada;
- b) acordar y controlar el alcance de las pruebas de auditoría técnica;
- c) limitar las pruebas de auditoría al acceso de solo lectura al software y los datos. Si el acceso de solo lectura no está disponible para obtener la información necesaria, ejecutar la prueba por un administrador experimentado que tenga los derechos de acceso necesarios en nombre del auditor;
- d) si se otorga el acceso, establecer y verificar los requisitos de seguridad (por ejemplo, antivirus y parches) de los dispositivos utilizados para acceder a los sistemas (por ejemplo, computadoras portátiles o tabletas) antes de permitir el acceso;
- e) solo permitir el acceso que no sea de solo lectura para copias aisladas de archivos del sistema, eliminándolos cuando se complete la auditoría, o brindándoles la protección adecuada si existe la obligación de mantener dichos archivos bajo los requisitos de documentación de auditoría;

- f) identificar y acordar solicitudes de procesamiento especial o adicional, como ejecutar herramientas de auditoría;
- g) ejecutar pruebas de auditoría que puedan afectar la disponibilidad del sistema fuera del horario comercial;
- h) supervisar y registrar todos los accesos con fines de auditoría y prueba.

Otra información

Las pruebas de auditoría y otras actividades de aseguramiento también pueden ocurrir en los sistemas de prueba y desarrollo, donde dichas pruebas pueden afectar, por ejemplo, la integridad del código o conducir a la divulgación de cualquier información confidencial que se encuentre en dichos entornos.

Anexo A
(informativo)

Usando atributos

A.1 Generalidades

Este anexo proporciona una tabla para demostrar el uso de atributos como una forma de crear diferentes vistas de los controles. Los cinco ejemplos de atributos son (ver4.2):

- a) Tipos de control (#Preventivo, #Detectivo, #Correctivo)
- b) Propiedades de seguridad de la información (#Confidencialidad, #Integridad, #Disponibilidad)
- c) Conceptos de ciberseguridad (#Identificar, #Proteger, #Detectar, #Responder, #Recuperar)
- d) Capacidades operativas (#Gobernanza, #Gestión_de_activos, #Protección_de_la_información, #Seguridad_de_recursos_humanos, #Seguridad_física, #Seguridad_de_sistemas_y_redes, #Seguridad_de_aplicaciones, # Configuración_segura, # Gestión_de_identidad_y_acceso, # Gestión_de_amenazas_y_vulnerabilidades, #Continuidad, #Seguridad_de_relaciones_con_proveedores, #Cumplimiento_y_legal, # Gestión_de_eventos_de_seguridad_de_la_información, #Garantía_de_seguridad_de_la_información)
- e) Dominios de seguridad (#Gobernanza_y_Ecosistema, #Protección, #Defensa, #Resiliencia)

Cuadro A.1 contiene una matriz de todos los controles en este documento con sus valores de atributo dados.

El filtrado o clasificación de la matriz se puede lograr mediante el uso de una herramienta como una hoja de cálculo simple o una base de datos, que puede incluir más información como texto de control, orientación, orientación o atributos específicos de la organización (verA.2).

Tabla A.1 — Matriz de controles y valores de atributos

YO ASI/ CEI 27002 control identificador	nombre de control	Tipo de control	Información seguridad propiedades	La seguridad cibernética conceptos	Operacional capacidades	Seguridad dominios
5.1	Políticas para información seguridad	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	# Gobernanza	# Gobernanza_ y_Ecosys- tema #Resil- iencia
5.2	Información roles de seguridad y responsabilidad Habilidades	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	# Gobernanza	# Gobernar- ance_y_ Ecosistema # Proteccion # Resiliencia
5.3	segregación de deberes	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Gobernanza # Identidad_y_ access_man- gestion	# Gobernanza_ y_Ecosys- tiempo
5.4	Gestión responsabilidad corbatas	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	# Gobernanza	# Gobernanza_ y_Ecosys- tiempo
5.5	Contactar con autoridades	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #Pro- tectar #Responder # Recuperar	# Gobernanza	# Defensa #Re- silencio

Cuadro A.1 (continuado)

YO ASI/ CEI 27002 control identificador	nombre de control	Tipo de control	Información seguridad propiedades	La seguridad cibernética conceptos	Operacional capacidades	Seguridad dominios
5.6	Contactar con inter especial est grupos	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Proteger # Responder #Re- cubrir	# Gobernanza	# Defensa
5.7	Inteligencia de amenazas gencia	# Preventivo # Detective # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #De- tectar #Responder	# amenaza_y_ vulnerabilidad_ gestión	# Defensa #Re- silencio
5.8	Información seguridad en hombre del proyecto - gestion	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #Pro- tectar	# Gobernanza	# Gobernanza_ y_Ecosys- artículo #Protec- ción
5.9	Inventario de información y otra asociado activos	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	# Asset_man- gestion	# Gobernanza_ y_Ecosys- artículo #Protec- ción
5.10	Uso aceptable de información y otra asociado activos	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Asset_man- gestion # Información_ proteccion	# Gobernanza_ y_Ecosys- artículo #Protec- ción
5.11	Retorno de activos	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Asset_man- gestion	# Proteccion
5.12	Clasificación de información	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	# Información_ proteccion	# Proteccion # Defensa
5.13	Etiquetado de información	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Información_ proteccion	# Defensa # Proteccion
5.14	Información transferir	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Asset_man- gestion # Información_ proteccion	# Proteccion
5.15	Control de acceso	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Identidad_y_ access_man- gestion	# Proteccion
5.16	hombre de identidad- gestion	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Identidad_y_ access_man- gestion	# Proteccion
5.17	Autenticación información	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Identidad_y_ access_man- gestion	# Proteccion
5.18	Derechos de acceso	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Identidad_y_ access_man- gestion	# Proteccion
5.19	Información seguridad en relación con el proveedor naciones	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	# Proveedor_re- lationships_se- seguridad	# Gobernanza_ y_Ecosys- artículo #Protec- ción

Cuadro A.1 (continuado)

YO ASI/ CEI 27002 control identificador	nombre de control	Tipo de control	Información seguridad propiedades	La seguridad cibernética conceptos	Operacional capacidades	Seguridad dominios
5.20	Direccionamiento información seguridad con- en proveedor acuerdos	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	# Proveedor_re- lationships_se- seguridad	# Gobernanza_ y_Ecosys- artículo #Protec- ción
5.21	Gerente información seguridad en la oferta TIC cadena	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	# Proveedor_re- lationships_se- seguridad	# Gobernanza_ y_Ecosys- artículo #Protec- ción
5.22	Monitor- ing, revisión y cambio gestión de proveedor servicios	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	# Proveedor_re- lationships_se- seguridad	# Gobernanza_ y_Ecosys- artículo #Protec- ción #Defensa # Información_ seguridad_como- seguro
5.23	Información seguridad para uso de la nube servicios	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Proveedor_re- lationships_se- seguridad	# Gobernanza_ y_Ecosys- artículo #Protec- ción
5.24	Información incidente de seguridad manejo de abolladuras - planeación mental y prepara- ción	# Correctivo	# Confidencial- #Integridad # Disponibilidad	# Responder #Re- cubrir	# Gobernanza # Informa- tion_securi- ty_event_man- gestion	# Defensa
5.25	Evaluación y decisión sobre informac- ción de seguridad eventos	# Detective	# Confidencial- #Integridad # Disponibilidad	# Detectar #Re- sponder	# Informa- tion_securi- ty_event_man- gestion	# Defensa
5.26	Respuesta a información incidente de seguridad abolladuras	# Correctivo	# Confidencial- #Integridad # Disponibilidad	# Responder #Re- cubrir	# Informa- tion_securi- ty_event_man- gestion	# Defensa
5.27	Aprendiendo de información incidente de seguridad abolladuras	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #Pro- tectar	# Informa- tion_securi- ty_event_man- gestion	# Defensa
5.28	Colección de evidencia	# Correctivo	# Confidencial- #Integridad # Disponibilidad	# Detectar #Re- sponder	# Informa- tion_securi- ty_event_man- gestion	# Defensa
5.29	Información seguridad durante interrupción	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Proteger #Re- sponder	# Continuidad	# Proteccion # Resiliencia
5.30	preparación para las TIC para negocios continuidad	# Correctivo	# Disponibilidad	# Responder	# Continuidad	# Resiliencia

Cuadro A.1 (continuado)

YO ASI/ CEI 27002 control identificador	nombre de control	Tipo de control	Información seguridad propiedades	La seguridad cibernética conceptos	Operacional capacidades	Seguridad dominios
5.31	legal, estatuto- ry, regulador y contrato- requerimiento tual mentos	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	#Legal_y_ cumplimiento	# Gobernanza_ y_Ecosys- artículo #Protec- ción
5.32	Intelectual propiedad derechos	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	#Legal_y_ cumplimiento	# Gobernanza_ y_Ecosys- tiempo
5.33	Proteccion DE registros	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #Pro- tectar	#Legal_y_ cumplimiento # Asset_man- gestion # Información_ proteccion	# Defensa
5.34	Privacidad y proteccion DE información personal	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #Pro- tectar	# Información_ proteccion #Legal_y_ cumplimiento	# Proteccion
5.35	Independiente repass de información seguridad	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #Pro- tectar	# Información_ seguridad_como- seguro	# Gobernanza_ y_Ecosys- tiempo
5.36	Cumplimiento con políticas, reglas y normas para información seguridad	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #Pro- tectar	#Legal_y_ cumplimiento # Información_ seguridad_como- seguro	# Gobernanza_ y_Ecosys- tiempo
5.37	documentado operando procedimientos	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Proteger #Re- cubrir	# Asset_man- gestion # fisio- cal_seguridad # Sistema_y_ network_secu- ridad #Aplicación ción_seguridad # Secure_con- figuración # Identidad_ y_acceso_ gestión # amenaza_y_ vulnerabilidad_ gestión # Continuidad # Informa- tion_securi- ty_event_man- gestion	# Gobernanza_ y_Ecosys- artículo #Protec- ción #Defensa
6.1	Poner en pantalla	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Human_re- source_secu- ridad	# Gobernanza_ y_Ecosys- tiempo

Cuadro A.1 (continuado)

YO ASI/ CEI 27002 control identificador	nombre de control	Tipo de control	Información seguridad propiedades	La seguridad cibernética conceptos	Operacional capacidades	Seguridad dominios
6.2	Términos y condiciones de empleo	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Human_re- source_secu- ridad	# Gobernanza_ y_Ecosys- tiempo
6.3	Información seguridad conciencia, educación y capacitación	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Human_re- source_secu- ridad	# Gobernanza_ y_Ecosys- tiempo
6.4	Disciplinario proceso	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Proteger #Re- responder	# Human_re- source_secu- ridad	# Gobernanza_ y_Ecosys- tiempo
6.5	responsabilidad Habilidades después terminación o cambio de empleo	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Human_re- source_secu- ridad #Activo_ gestión	# Gobernanza_ y_Ecosys- tiempo
6.6	confiado- lidad o no divulgación acuerdos	# Preventivo	# Confidencial alidad	# Proteger	# Human_re- source_secu- rity #Info- mation_pro- tección # Proveedor_re- relaciones	# Gobernanza_ y_Ecosys- tiempo
6.7	Trabajo remoto- En g	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Asset_man- gestion # Información_ proteccion # Physical_se- seguridad #Sys- tem_and_net- trabajo_seguridad	# Proteccion
6.8	Información evento de seguridad reportando	# Detective	# Confidencial- #Integridad # Disponibilidad	# Detectar	# Informa- tion_securi- ty_event_man- gestion	# Defensa
7.1	Seguridad física perimetral- ters	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Physical_se- seguridad	# Proteccion
7.2	Entrada física	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Physical_se- seguridad #Iden- tity_and_Ac- cess_Manage- mento	# Proteccion
7.3	Oficina de seguridad es, habitaciones y instalaciones	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Physical_se- calidad #Activo_ gestión	# Proteccion
7.4	Seguridad física monitor de rity- En g	# Preventivo # Detective	# Confidencial- #Integridad # Disponibilidad	# Proteger #De- tectar	# Physical_se- seguridad	# Proteccion # Defensa

Cuadro A.1 (continuado)

YO ASI/ CEI 27002 control identificador	nombre de control	Tipo de control	Información seguridad propiedades	La seguridad cibernética conceptos	Operacional capacidades	Seguridad dominios
7.5	Proteger- en contra físico y ambiental amenazas	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Physical_se- seguridad	# Proteccion
7.6	Trabajando en áreas seguras	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Physical_se- seguridad	# Proteccion
7.7	Limpiar el escritorio y pantalla clara	# Preventivo	# Confidencial alidad	# Proteger	# Physical_se- seguridad	# Proteccion
7.8	Equipo ubicación y proteccion	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Physical_se- calidad #Activo_ gestión	# Proteccion
7.9	seguridad de as- pone en marcha ises	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Physical_se- calidad #Activo_ gestión	# Proteccion
7.10	Medios de almacenamiento	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Physical_se- calidad #Activo_ gestión	# Proteccion
7.11	Secundario utilidades	# Preventivo # Detective	# Integridad # Disponibilidad	# Proteger #De- tectar	# Physical_se- seguridad	# Proteccion
7.12	Seguridad de cableado ridad	# Preventivo	# Confidencial alidad #Disponible- habilidad	# Proteger	# Physical_se- seguridad	# Proteccion
7.13	Equipo mantenimiento	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Physical_se- calidad #Activo_ gestión	# Proteccion # Resiliencia
7.14	Eliminación segura al o reutilización de equipo	# Preventivo	# Confidencial alidad	# Proteger	# Physical_se- calidad #Activo_ gestión	# Proteccion
8.1	Punto final de usuario dispositivos	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Asset_man- gestion # Información_ proteccion	# Proteccion
8.2	Privilegiado derechos de acceso	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Identidad_y_ access_man- gestion	# Proteccion
8.3	Información restricción de acceso ción	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Identidad_y_ access_man- gestion	# Proteccion
8.4	El acceso a los código fuente	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Identidad_ y_acceso_ gestión # Aplica- ción_seguridad # Secure_con- figuración	# Proteccion
8.5	autenticación segura ticación	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Identidad_y_ access_man- gestion	# Proteccion

Cuadro A.1 (continuado)

YO ASI/ CEI 27002 control identificador	nombre de control	Tipo de control	Información seguridad propiedades	La seguridad cibernética conceptos	Operacional capacidades	Seguridad dominios
8.6	capacidad hombre- gestion	# Preventivo # Detective	# Integridad # Disponibilidad	# Identificar #Pro- detectar #Detectar	# Continuidad	# Gobernanza_ y_Ecosys- artículo #Protec- ción
8.7	Proteccion contra mal- mercancia	# Preventivo # Detective # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Proteger #De- tectar	# Sistema_y_ network_secu- ridad #Informa- tion_protec- ción	# Proteccion # Defensa
8.8	Gestión de técnico vulnerabilidades	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #Pro- tectar	# amenaza_y_ vulnerabilidad_ gestión	# Gobernanza_ y_Ecosys- artículo #Protec- ción #Defensa
8.9	Configuración gestión	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Secure_con- figuración	# Proteccion
8.10	Información supresión	# Preventivo	# Confidencial alidad	# Proteger	# Información_ proteccion #Legal_y_ cumplimiento	# Proteccion
8.11	Enmascaramiento de datos	# Preventivo	# Confidencial alidad	# Proteger	# Información_ proteccion	# Proteccion
8.12	Fuga de datos prevención	# Preventivo # Detective	# Confidencial alidad	# Proteger #De- tectar	# Información_ proteccion	# Proteccion # Defensa
8.13	Información respaldo	# Correctivo	# Integridad # Disponibilidad	# Recuperar	# Continuidad	# Proteccion
8.14	Redundancia de información Procesando instalaciones	# Preventivo	# Disponibilidad	# Proteger	# Continuidad # Asset_man- gestion	# Proteccion # Resiliencia
8.15	Inicio sesión	# Detective	# Confidencial- #Integridad # Disponibilidad	# Detectar	# Informa- tion_securi- ty_event_man- gestion	# Proteccion # Defensa
8.16	Supervisión actividades	# Detective # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Detectar #Re- sponder	# Informa- tion_securi- ty_event_man- gestion	# Defensa
8.17	reloj sincronizado- nización	# Detective	# Integridad	# Proteger #De- tectar	# Informa- tion_securi- ty_event_man- gestion	# Proteccion # Defensa
8.18	uso de utilidad legítima programas	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Sistema_y_ network_secu- ridad #Secure_ configuración # Solicitud_ seguridad	# Proteccion
8.19	Instalación de software en Operacional sistemas	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Secure_con- figuración # Solicitud_ seguridad	# Proteccion

Cuadro A.1 (continuado)

YO ASI/ CEI 27002 control identificador	nombre de control	Tipo de control	Información seguridad propiedades	La seguridad cibernética conceptos	Operacional capacidades	Seguridad dominios
8.20	Redes seguridad	# Preventivo # Detective	# Confidencial- #Integridad # Disponibilidad	# Proteger #De- tectar	# Sistema_y_ network_secu- ridad	# Proteccion
8.21	Seguridad de servicio de red vicios	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Sistema_y_ network_secu- ridad	# Proteccion
8.22	segregación de redes	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Sistema_y_ network_secu- ridad	# Proteccion
8.23	Filtrado web	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Sistema_y_ network_secu- ridad	# Proteccion
8.24	Uso de crip- tografía	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Secure_con- figuración	# Proteccion
8.25	desarrollo seguro opment vida ciclo	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Aplica- ción_seguridad # Sistema_y_ network_secu- ridad	# Proteccion
8.26	Solicitud re-seguridad requisitos	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Aplica- ción_seguridad # Sistema_y_ network_secu- ridad	# Proteccion # Defensa
8.27	sistema seguro arquitectura e ingeniero- principios de formación	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Aplica- ción_seguridad # Sistema_y_ network_secu- ridad	# Proteccion
8.28	Codificación segura	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Aplica- ción_seguridad # Sistema_y_ network_secu- ridad	# Proteccion
8.29	Seguridad prueba en de- sarrollo y aceptación	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Identificar	# Aplica- ción_seguridad # Informa- tion_securi- ty_assurance # Sistema_y_ network_secu- ridad	# Proteccion
8.30	subcontratado desarrollo	# Preventivo # Detective	# Confidencial- #Integridad # Disponibilidad	# Identificar #Pro- detectar #Detectar	# Sistema_y_ network_secu- ridad #Aplicación ción_seguridad # Proveedor_re- lationships_se- seguridad	# Gobernanza_ y_Ecosys- artículo #Protec- ción

Cuadro A.1 (continuado)

YO ASI/ CEI 27002 control identificador	nombre de control	Tipo de control	Información seguridad propiedades	La seguridad cibernética conceptos	Operacional capacidades	Seguridad dominios
8.31	Separación de desarrollo-prueba, prueba y producción ambientes	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Aplicación_seguridad # Sistema_y_network_securidad	# Protección
8.32	Cambia hombre - gestion	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Aplicación_seguridad # Sistema_y_network_securidad	# Protección
8.33	Información de prueba ción	# Preventivo	# Confidencial- #Integridad	# Proteger	# Información_proteccion	# Protección
8.34	Proteccion de información sistemas de ción durante la auditoría pruebas	# Preventivo	# Confidencial- #Integridad # Disponibilidad	# Proteger	# Sistema_y_network_securidad # Información_proteccion	# Gobernanza_y_Ecosys-artículo #Protección

[Tabla A.2](#) muestra un ejemplo de cómo crear una vista filtrando por un valor de atributo particular, en este caso #Corrective.

Tabla A.2 — Vista de #Controles Correctivos

YO ASI/ CEI 27002 control identificador	nombre de control	Tipo de control	Información seguridad propiedades	La seguridad cibernética conceptos	Operacional capacidades	Seguridad dominios
5.5	Contactar con autoridades	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #Proteger #Responder # Recuperar	# Gobernanza	# Defensa #Resiliencia
5.6	Contactar con inter especial est grupos	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Proteger # Responder #Recubrir	# Gobernanza	# Defensa
5.7	Inteligencia de amenazas gencia	# Preventivo # Detective # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Identificar #Detectar #Responder	# amenaza_y_vulnerabilidad_gestión	# Defensa #Resiliencia
5.24	Información incidente de seguridad manejo de abolladuras - planeación mental y preparación	# Correctivo	# Confidencial- #Integridad # Disponibilidad	# Responder #Recubrir	# Gobernanza # Información_security_event_management	# Defensa
5.26	Respuesta a información incidente de seguridad abolladuras	# Correctivo	# Confidencial- #Integridad # Disponibilidad	# Responder #Recubrir	# Información_security_event_management	# Defensa
5.28	Colección de evidencia	# Correctivo	# Confidencial- #Integridad # Disponibilidad	# Detectar #Responder	# Información_security_event_management	# Defensa
5.29	Información seguridad durante-interrupción	# Preventivo # Correctivo	# Confidencial- #Integridad # Disponibilidad	# Proteger #Responder	# Continuidad	# Protección # Resiliencia